Mini Project Report

on

BondHealth

Submitted by

Mariyam Rahim (20223068)
Pillai Anjita (20223079)
Sneha Vijayan (20223099)
Soya R F (20223101)
Thara Asharaf (20223108)

In partial fulfilment of the requirements for the award of degree of Bachelor of Technology in Computer Science and Engineering.

DIVISION OF COMPUTER SCIENCE AND ENGINEERING
SCHOOL OF ENGINEERING
COCHIN UNIVERSITY OF SCIENCE AND TECHNOLOGY

APRIL 2026

DIVISION OF COMPUTER SCIENCE AND ENGINEERING
SCHOOL OF ENGINEERING
COCHIN UNIVERSITY OF SCIENCE AND TECHNOLOGY

CERTIFICATE

Certified that this is a Mini Project Report titled

BondHealth

Submitted by

Mariyam Rahim (20223068)
Pillai Anjita (20223079)
Sneha Vijayan (20223099)
Soya R F (20223101)
Thara Asharaf (20223108)

of VI Semester, Computer Science and Engineering in the year 2024 in partial fulfillment requirements for the award of degree of Bachelor of Technology in Computer Science and Engineering of Cochin University of Science and Technology.

Mr. Pramod Pavithran	Ms. Sheena S	Ms. Sheena S
Head of Division	**Project Coordinator**	**Project Guide**

ABSTRACT

BondHealth is a comprehensive digital healthcare ecosystem designed to unify patient care across multiple healthcare providers. This project addresses the critical challenge of fragmented medical records by creating a centralized platform where patients' medical history, appointments, and lab results are securely accessible across all connected hospitals.

The system features role-based dashboards for patients, doctors, hospital administrators, and lab technicians. Key functionalities include appointment scheduling, electronic medical records management, lab report integration, prescription management, and a public review system. Built with Node.js and Express on the backend, PostgreSQL for data persistence, and vanilla JavaScript with Tailwind CSS for the frontend, BondHealth demonstrates a production-ready healthcare management solution.

The platform implements robust authentication using JWT tokens, role-based access control, and comprehensive API endpoints for all operations. With features like real-time appointment management, leave tracking for doctors, and a dynamic review system, BondHealth provides a seamless experience for all stakeholders in the healthcare delivery chain.

Keywords: Healthcare Management System, Electronic Medical Records, Patient Portal, Telemedicine, Hospital Management, Node.js, PostgreSQL, JWT Authentication, Role-Based Access Control

Contents

ABSTRACT i

1 Introduction 1

1.1 Problem Statement . . . 1
1.2 Objectives . . . 2
1.3 Scope of the Project . . . 2
1.3.1 Geographical Scope . . . 2
1.3.2 Functional Scope . . . 2
1.3.3 Technical Scope . . . 3

2 SYSTEM STUDY 4

2.1 Introduction . . . 4
2.2 Existing System . . . 4
2.2.1 Current Healthcare Challenges . . . 4
2.2.2 Disadvantages of Existing System . . . 4
2.3 Proposed System . . . 5
2.3.1 System Overview . . . 5
2.3.2 Advantages of Proposed System . . . 5
2.4 Feasibility Study . . . 5
2.4.1 Technical Feasibility . . . 5
2.4.2 Operational Feasibility . . . 6
2.4.3 Economic Feasibility . . . 6
2.5 Requirements Analysis . . . 6
2.5.1 Functional Requirements . . . 6
2.5.1.1 Patient Module . . . 6
2.5.1.2 Doctor Module . . . 7
2.5.1.3 Hospital Admin Module . . . 7
2.5.1.4 Lab Technician Module . . . 7
2.5.2 Non-Functional Requirements . . . 7
2.5.2.1 Performance Requirements . . . 7
2.5.2.2 Security Requirements . . . 8
2.5.2.3 Usability Requirements . . . 8
2.5.2.4 Reliability Requirements . . . 8
2.6 System Architecture Overview . . . 8
2.7 System Modules . . . 9
2.7.1 Authentication Module . . . 9
2.7.2 Patient Management Module . . . 9
2.7.3 Appointment Management Module . . . 9
2.7.4 Reporting Module . . . 10

2.8 User Roles and Permissions 10
2.9 Summary 10

3 System Design **11**
3.1 System Architecture Overview 11
3.1.1 Presentation Layer (Client Tier) 11
3.1.2 Application Layer (Business Tier) 12
3.1.3 Data Layer (Database Tier) 13
3.2 Data Flow Diagrams 14
3.2.1 Appointment Booking Data Flow 15
3.2.2 Lab Report Processing Data Flow 17
3.2.3 Payment Processing Data Flow 19
3.3 Use Case Diagrams 21
3.3.1 Patient Use Cases 22
3.3.2 Doctor Use Cases 24
3.3.3 Admin Use Cases 27
3.3.4 Lab Technician Use Cases 30
3.4 Database Schema Design (Neon PostgreSQL) 33
3.5 API Design (RESTful Endpoints) 35
3.6 Module-wise Detailed Design 36
3.6.1 Authentication Module 36
3.6.2 Patient Dashboard Module 38
3.6.3 Doctor Dashboard Module 41
3.6.4 Admin Dashboard Module 44
3.6.5 Lab Technician Module 47
3.6.6 Appointment Booking Module 49
3.6.7 Payment Integration Module 52
3.6.8 Real-time Chat Module 55
3.6.9 Notification Module 58
3.7 Security Architecture 61
3.7.1 Authentication Security 62
3.7.2 Data Security 63
3.7.3 Application Security 64
3.7.4 Infrastructure Security 64
3.7.5 Compliance and Audit 65
3.8 Database Connection Design (Neon PostgreSQL) 66
3.8.1 Connection Pooling Architecture 67
3.8.2 Connection Implementation 67
3.8.3 Connection Security 70
3.8.4 Error Handling and Retry Logic 70
3.8.5 Monitoring and Alerting 71
3.9 Third-party Integrations 71

3.9.1 Integration Architecture Principles 71
3.9.2 Payment Gateway Integration Details 72
3.9.3 File Storage Integration Details 73
3.9.4 Notification Service Integration Details 73
3.10 Performance Optimization 73

List of Figures

2.1 BondHealth Three-Tier Architecture 8

List of Tables

2.1 User Roles and Access Levels 10

3.1 Users Schema - Core table storing authentication credentials and base user information for all system users. This table serves as the foundation for role-based access control and contains the minimal data required for authentication and session management. Each user has a unique identifier and can be associated with a hospital if they are staff (doctors, admins, lab technicians). 76

3.2 Hospitals Schema - Stores comprehensive information about healthcare facilities registered in the BondHealth platform. Each hospital can have multiple doctors and lab technicians associated with it. The table includes both contact information and classification details for filtering and reporting. 77

3.3 Patients Schema - Extended profile information for users with role='patient'. Contains medical information, emergency contacts, and healthcare-specific data fields. The use of array data types (TEXT[]) allows efficient storage of multiple medical conditions and allergies without creating separate junction tables, simplifying queries and improving performance. 78

3.4 Doctors Schema - Comprehensive profile information for healthcare providers. Includes professional details, availability patterns, and performance metrics. The `available_days` array stores days of the week when the doctor practices, enabling flexible scheduling patterns. The rating is calculated from patient feedback. 79

3.5 Appointments Schema - Core transactional table recording all patient-doctor appointments. Tracks the complete lifecycle from booking through completion or cancellation. Includes status tracking, timing information, and audit fields. Each appointment is uniquely identified and linked to patient, doctor, and hospital. 80

3.6 Lab Reports Schema - Stores all laboratory test results and related information. Supports file attachments, priority levels, and sharing preferences. Enables complete tracking of the lab workflow from test order to result delivery, with appropriate metadata for clinical context. 81

3.7 Prescriptions Schema - Manages medication prescriptions issued by doctors. Supports active prescription tracking, refill management, and medication history. Each prescription record represents a single medication with dosage instructions, allowing for multiple medications per consultation. 82

3.8 Doctor Leave Schema - Tracks leave applications and approvals for doctors. Ensures appointment availability reflects leave periods and enables coverage planning. Supports date ranges and status tracking for approval workflow. 83

3.9 Medicines Inventory Schema - Manages hospital pharmacy inventory, tracking stock levels, pricing, and expiry dates. Enables automated reorder alerts and expiry notifications to ensure medication availability and patient safety. 84
3.10 Payments Schema - Records all financial transactions processed through the platform. Links to appointments for context, tracks payment status, and stores gateway transaction references for reconciliation. Supports multiple payment methods and currencies. 85
3.11 Messages Schema (Real-time Chat) - Stores all chat communications between patients and doctors. Supports text messages and file attachments, with read receipts for delivery tracking. Used for both real-time and asynchronous communication, maintaining complete conversation history for medical-legal purposes. 86
3.12 Authentication Endpoints - Public endpoints for user registration, login, and session management. These endpoints handle identity verification, token issuance, and session lifecycle. All authentication endpoints use HTTPS exclusively to prevent credential interception. 87
3.13 Patient Endpoints - Comprehensive set of endpoints for patient-facing functionality. All endpoints require patient role authentication and provide access to patient-specific data. Responses are filtered to include only information relevant to the authenticated patient. 88
3.14 Doctor Endpoints - Endpoints for doctor-specific functionality. All endpoints require doctor role authentication and provide access to patient data and clinical tools. Responses include only patients assigned to or seen by the authenticated doctor. 89
3.15 Admin Endpoints - Administrative endpoints for hospital management. All endpoints require admin role authentication and provide comprehensive control over hospital operations, user management, and system configuration. 90
3.16 Lab Technician Endpoints - Endpoints for laboratory workflow management. All endpoints require lab role authentication and provide tools for test processing, result entry, and report management. 91
3.17 Payment Endpoints - Endpoints for payment processing and financial transactions. Access varies by role, with patients able to view their own payments and admins having full access for reconciliation and management. 92
3.18 Chat Endpoints - Endpoints for real-time messaging between patients and doctors. Supports both REST for history retrieval and WebSocket for real-time communication. All messages are encrypted and stored for medical-legal purposes. 93
3.19 Security Features Summary - Comprehensive overview of security controls implemented across all layers of the BondHealth platform. Each control is described with its implementation details and purpose. 94

3.20 Third-party Integrations - Comprehensive list of all external services integrated with the BondHealth platform, including purpose, implementation details, and compliance considerations. Each integration is chosen for reliability and healthcare compliance. 95

Chapter 1

Introduction

The healthcare industry today faces significant challenges in managing and accessing patient medical information. In the current system, patient data is often scattered across multiple hospitals and healthcare providers, creating fragmented medical histories that are difficult to access when needed. This fragmentation leads to several critical issues: patients become dependent on physical reports, undergo repeated diagnostic tests, face limited options for remote consultations, and encounter difficulties in obtaining certain medications, especially rare ones. Additionally, hospitals operate without a common digital platform to efficiently manage patient data and streamline interactions between healthcare providers and patients.

The digital transformation of healthcare has become increasingly important in recent years, with the COVID-19 pandemic highlighting the urgent need for remote healthcare solutions. Patients, particularly the elderly and those with mobility issues, require accessible healthcare services that do not always necessitate physical hospital visits. Furthermore, the need for a centralized, secure system to store and access medical records has become paramount in ensuring continuity of care and improving healthcare outcomes.

1.1 Problem Statement

The existing healthcare ecosystem suffers from the following key problems:

- **Fragmented Medical Records**: Patient medical information is distributed across different hospitals, making it difficult to obtain complete medical histories when required for diagnosis or treatment.
- **Dependency on Physical Reports**: Patients must carry physical copies of their medical reports, which can be lost, damaged, or forgotten during emergencies.
- **Repeated Diagnostic Tests**: Due to inaccessible medical histories, patients often undergo redundant tests, increasing healthcare costs and inconvenience.
- **Limited Remote Consultation Options**: Many patients, especially the elderly and those in remote areas, struggle to access healthcare services that require physical presence.
- **Difficulty in Obtaining Medications**: Patients face challenges in locating and purchasing rare or specific medicines that may only be available at certain hospital pharmacies.
- **Lack of a Common Digital Platform**: Hospitals lack a unified digital interface to efficiently manage patient data, appointments, consultations, and billing processes.

1.2 Objectives

The primary objectives of the BondHealth project are:

1. **Develop a Centralized Digital Platform**: Create a web-based healthcare platform that connects hospitals and patients within a specific geographical area, functioning as a digital interface for healthcare services.
2. **Implement Digital Patient Identities**: Provide unique, secure digital IDs to patients (similar to DigiLocker) for storing and accessing medical records including consultation history, diagnostic reports, and medical scans.
3. **Enable Hospital Discovery**: Display registered hospitals along with available departments and doctor information, allowing patients to make informed decisions about their healthcare providers.
4. **Facilitate Remote Consultations**: Support scheduled chat and video call consultations between patients and doctors, making healthcare accessible to those unable to visit hospitals in person.
5. **Integrate Pharmacy Services**: Enable online purchase of medicines, including rare medications, from hospital pharmacies with electronic billing for transparent, paperless transactions.
6. **Ensure Security and Privacy**: Implement robust security measures to protect sensitive patient data and ensure compliance with healthcare data protection standards.

1.3 Scope of the Project

The scope of BondHealth encompasses the following aspects:

1.3.1 Geographical Scope

The platform initially targets a specific geographical area, connecting hospitals and patients within that region. This focused approach allows for better management, testing, and refinement of the system before potential expansion to wider areas.

1.3.2 Functional Scope

- **Patient Registration and Authentication**: Secure registration process assigning unique patient IDs with robust authentication mechanisms.
- **Medical Records Management**: Digital storage and retrieval of consultation histories, diagnostic reports, and medical scans.

- **Hospital and Doctor Directory**: Comprehensive listing of registered hospitals with department-wise doctor information.
- **Teleconsultation Services**: Scheduling and conducting remote consultations through chat and video calls.
- **Online Pharmacy**: E-commerce functionality for medicine purchases from hospital pharmacies.
- **Electronic Billing**: Digital invoice generation and payment processing for consultations and medicine purchases.

1.3.3 Technical Scope

The project involves developing a responsive web application using modern web technologies, implementing secure database management for medical records, integrating video calling APIs for teleconsultation, and ensuring data encryption and privacy compliance.

Chapter 2

SYSTEM STUDY

2.1 Introduction

The system study phase involves understanding the existing healthcare management challenges and analyzing the requirements for BondHealth. This chapter covers the problem definition, feasibility analysis, and detailed requirements gathering for the proposed system.

2.2 Existing System

2.2.1 Current Healthcare Challenges

- **Fragmented Medical Records:** Patient data is scattered across different hospitals, clinics, and laboratories with no central access.
- **Manual Appointment Management:** Many healthcare facilities still rely on phone calls and paper-based appointment scheduling.
- **Delayed Lab Results:** Test reports take days to reach doctors and patients due to manual delivery systems.
- **Lack of Patient Engagement:** Patients have limited access to their own health information and medical history.
- **Administrative Inefficiency:** Hospital staff spend excessive time on paperwork and manual data entry.

2.2.2 Disadvantages of Existing System

- No centralized patient health record system
- Increased wait times for appointments and results
- Higher chances of medical errors due to missing information
- Poor communication between different healthcare providers
- Limited scalability for growing healthcare networks

2.3 Proposed System

2.3.1 System Overview

BondHealth is a web-based healthcare management platform that connects patients, doctors, hospitals, and laboratories on a single unified system. The platform provides:

- **Centralized Patient Records:** Complete medical history accessible to authorized healthcare providers
- **Online Appointment System:** 24/7 appointment booking with real-time availability
- **Digital Lab Reports:** Instant sharing of test results between labs, doctors, and patients
- **Role-Based Dashboards:** Customized interfaces for different user types
- **Secure Authentication:** JWT-based authentication with role-based access control

2.3.2 Advantages of Proposed System

- Seamless access to patient medical history across all connected hospitals
- Reduced wait times through online appointment scheduling
- Instant delivery of lab reports to doctors and patients
- Enhanced patient engagement through personal health portal
- Improved administrative efficiency with automated workflows
- Scalable architecture for future expansion

2.4 Feasibility Study

2.4.1 Technical Feasibility

The system is technically feasible as it uses:

- **Node.js & Express:** Proven backend technology for building scalable web applications
- **PostgreSQL:** Robust relational database with excellent performance and data integrity
- **JWT Authentication:** Industry standard for secure API authentication
- **Responsive Design:** Works seamlessly on desktops, tablets, and mobile devices

2.4.2 Operational Feasibility

The system is operationally feasible because:

- User-friendly interfaces require minimal training for staff
- Role-based dashboards simplify daily tasks for each user type
- Automated notifications reduce manual follow-up work
- Centralized records eliminate redundant data entry

2.4.3 Economic Feasibility

The system offers significant economic benefits:

- Reduced administrative costs through automation
- Elimination of paper-based systems and storage
- Improved staff productivity and efficiency
- Scalable architecture grows with organizational needs
- Open-source technology stack minimizes licensing costs

2.5 Requirements Analysis

2.5.1 Functional Requirements

2.5.1.1 Patient Module

- User registration and profile management
- View and manage appointments
- Book new appointments with available doctors
- Access medical reports and prescriptions
- Update personal and emergency contact information
- Write and view public reviews

2.5.1.2 Doctor Module

- View today's appointment schedule
- Access patient medical history
- Review and add findings to lab reports
- Manage availability and leave requests
- Communicate with patients

2.5.1.3 Hospital Admin Module

- Register new doctors and staff
- Manage medicine inventory
- Add laboratory facilities
- View hospital statistics and reports
- Manage doctor leave schedules

2.5.1.4 Lab Technician Module

- Upload and manage lab reports
- Update report status (pending/completed)
- Share results with doctors and patients
- View pending test requests

2.5.2 Non-Functional Requirements

2.5.2.1 Performance Requirements

- Page load time should be less than 3 seconds
- System should handle 1000+ concurrent users
- Database queries should execute within 500ms
- API response time under 200ms for standard operations

2.5.2.2 Security Requirements

- All passwords must be hashed using bcrypt
- JWT tokens for API authentication with 7-day expiration
- Role-based access control for all operations
- Session management with active session tracking
- Secure cookie handling with HttpOnly flag

2.5.2.3 Usability Requirements

- Intuitive interface requiring minimal training
- Responsive design for all device sizes
- Clear error messages and user feedback
- Consistent navigation across all modules

2.5.2.4 Reliability Requirements

- 99.9% uptime during business hours
- Data backup and recovery procedures
- Transaction integrity for critical operations
- Graceful error handling without data loss

2.6 System Architecture Overview

Three-Tier Architecture

- **Presentation Layer:** HTML, CSS, JavaScript, Tailwind CSS
- **Application Layer:** Node.js, Express.js
- **Data Layer:** PostgreSQL Database

Figure 2.1: BondHealth Three-Tier Architecture

The BondHealth system follows a three-tier architecture:

1. **Client Tier:** Web browsers render HTML pages with dynamic content fetched via API calls

2. **Application Tier:** Express.js server handles HTTP requests, implements business logic, and manages authentication
3. **Data Tier:** PostgreSQL database stores all application data with proper relationships and constraints

2.7 System Modules

2.7.1 Authentication Module

Handles user registration, login, and session management. Implements:

- JWT token generation and verification
- Password hashing with bcrypt
- Role-based access control
- Session tracking and management

2.7.2 Patient Management Module

Manages all patient-related operations:

- Profile creation and updates
- Medical history tracking
- Appointment scheduling
- Report and prescription access

2.7.3 Appointment Management Module

Handles the complete appointment lifecycle:

- Real-time availability checking
- Appointment booking, rescheduling, and cancellation
- Conflict detection and prevention
- Status tracking and notifications

2.7.4 Reporting Module

Manages lab reports and medical documents:

- Report upload and storage
- Status tracking (pending/reviewed)
- Secure sharing between stakeholders
- Historical data access

2.8 User Roles and Permissions

Role	Permissions
Patient	View own records, book appointments, access reports
Doctor	View appointments, access patient history, review reports
Hospital Admin	Manage doctors, staff, inventory, view analytics
Lab Technician	Upload reports, update status, share results

Table 2.1: User Roles and Access Levels

2.9 Summary

The system study phase has established a clear understanding of the existing healthcare challenges and defined comprehensive requirements for BondHealth. The proposed system addresses critical gaps in patient data management, appointment scheduling, and report sharing. With its modular architecture, role-based access control, and focus on usability, BondHealth is well-positioned to transform healthcare delivery in connected facilities.

Chapter 3

System Design

This chapter presents the comprehensive system design of the BondHealth healthcare platform, detailing the architectural decisions, data flow, database schema, API design, module specifications, security architecture, and third-party integrations that form the foundation of the unified digital healthcare ecosystem. The system design follows industry best practices for healthcare applications, ensuring scalability, security, maintainability, and seamless connectivity between patients, doctors, hospital administrators, and laboratory technicians.

3.1 System Architecture Overview

The BondHealth platform is built on a robust three-tier architecture that ensures scalability, maintainability, and security while providing seamless connectivity between patients, doctors, hospital administrators, and laboratory technicians. The architecture follows industry best practices for healthcare applications, with clear separation of concerns between presentation, business logic, and data persistence layers. This three-tier approach enables independent development, deployment, and scaling of each layer while maintaining secure communication between them.

3.1.1 Presentation Layer (Client Tier)

The presentation layer serves as the user interface through which all stakeholders interact with the BondHealth platform. It utilizes server-side rendered HTML with Tailwind CSS framework to deliver responsive, mobile-first design across all devices including desktops, tablets, and smartphones. The server-side rendering approach offers several critical advantages for healthcare applications:

- **Fast Initial Page Loads**: HTML is generated on the server and sent to the client, reducing client-side processing and improving time-to-interactive metrics, which is crucial for emergency healthcare scenarios where every second counts.
- **Improved SEO Capabilities**: Search engines can easily crawl and index server-rendered content, making healthcare services more discoverable to patients searching for medical assistance in their area.
- **Enhanced Security**: Business logic remains on the server, minimizing client-side exposure of sensitive healthcare algorithms and reducing attack vectors for malicious users attempting to access patient data.

- **Consistent User Experience**: The interface adapts seamlessly to different screen sizes and devices, ensuring healthcare professionals can access patient data from any location - whether at their desk, on hospital rounds with tablets, or responding to emergencies via mobile phones.
- **Accessibility Compliance**: The presentation layer implements WCAG 2.1 guidelines, ensuring the platform is usable by individuals with disabilities, including screen reader compatibility and keyboard navigation support for users with mobility impairments.

The user interface is organized into role-specific dashboards, each optimized for the unique workflows of different user types. Patient dashboards focus on appointment management and medical record access, doctor dashboards prioritize clinical workflow efficiency, admin dashboards provide comprehensive hospital management capabilities, and lab technician dashboards streamline test processing and result reporting. Each dashboard presents information in a clear, hierarchical manner with the most critical information displayed prominently.

3.1.2 Application Layer (Business Tier)

The application layer forms the core of the BondHealth platform, implementing all business logic, validation rules, workflow orchestration, and security controls. It is built using Node.js with the Express framework, providing a lightweight, event-driven architecture ideal for handling concurrent healthcare transactions. This layer processes all incoming requests, applies business rules, and coordinates responses between the presentation and data layers.

Key Components of the Application Layer:

1. **RESTful API Endpoints**: Well-defined endpoints following REST conventions handle all client requests, with appropriate HTTP methods (GET, POST, PUT, DELETE) and status codes ensuring predictable interactions. Each endpoint is documented using OpenAPI/Swagger specifications.
2. **Authentication Middleware**: JWT-based authentication verifies user identity for every protected request, with middleware functions that extract tokens from HTTP-only cookies and validate them against the active sessions store. Failed authentication attempts are logged and can trigger account lockout mechanisms.
3. **Role-Based Access Control (RBAC)**: Middleware functions check user roles against required permissions for each endpoint, ensuring patients cannot access doctor functions, administrators can manage hospital operations, and laboratory technicians can only access test-related features. This implements the principle of least privilege throughout the application.

4. **Request Validation Layer**: All incoming data is validated against predefined schemas using express-validator, preventing malformed or malicious data from reaching the database. Validation includes type checking, format validation (email, phone, dates), sanitization to remove potentially harmful content, and business rule enforcement such as checking appointment availability before booking.

5. **Error Handling Middleware**: Centralized error handling captures, logs, and appropriately responds to exceptions, providing meaningful error messages to clients while masking sensitive implementation details. Different error types (validation errors, authentication failures, server errors) receive appropriate HTTP status codes and user-friendly messages.

6. **Microservices-Oriented Design**: The application is organized into loosely coupled modules that can be independently scaled based on demand. The appointment booking service, payment processing service, real-time chat service, and notification service can each be deployed and scaled separately, allowing efficient resource utilization during peak usage periods such as morning appointment booking rushes.

7. **Request Rate Limiting**: Protection against denial-of-service attacks through configurable rate limiting per IP address and per user account, with stricter limits on authentication endpoints to prevent brute-force attacks. Different endpoints have different rate limits based on their sensitivity and resource requirements.

The application layer also implements comprehensive logging and monitoring, capturing request/response cycles, performance metrics, and error conditions for operational visibility and debugging. All logs are structured and centralized for easy analysis and alerting.

3.1.3 Data Layer (Database Tier)

The data layer manages all persistent storage for the BondHealth platform, implementing robust data modeling, access patterns, and security controls. Neon PostgreSQL serves as the primary database, leveraging serverless architecture for automatic scaling based on demand, eliminating the need for capacity planning while ensuring consistent performance during traffic spikes.

Database Technology Stack Features:

- **Neon PostgreSQL**: Serverless PostgreSQL offering with built-in connection pooling, automatic failover, and point-in-time recovery capabilities. The serverless architecture means the database scales to zero during low activity periods (such as nights) and instantly scales up during peak loads, optimizing costs while maintaining performance. This is particularly valuable for healthcare applications that may have unpredictable usage patterns.

- **Connection Pooling**: Implemented through the `@neondatabase/serverless` package, maintaining a configurable pool of database connections that are reused

across requests. This eliminates the overhead of establishing new connections for each operation and prevents connection exhaustion under load. The pool size is dynamically adjusted based on current demand.

- **UUID Primary Keys**: All tables use UUID v4 as primary keys instead of sequential integers, providing several advantages for healthcare applications:
  - Distributed uniqueness allows safe data merging across multiple hospital instances if the platform expands
  - Prevents enumeration attacks where sequential IDs would reveal data volume and patterns
  - Enables offline record creation with guaranteed uniqueness when synchronized later
  - Simplifies sharding and distributed database architectures
- **PostgreSQL Array Data Types**: Multi-value fields such as medical conditions, allergies, and doctor availability days are stored as native PostgreSQL arrays, providing efficient storage and querying capabilities while maintaining data integrity through type enforcement. This eliminates the need for separate junction tables for simple lists.
- **Foreign Key Constraints**: Referential integrity is enforced through foreign key relationships between tables, ensuring that orphaned records cannot exist and that operations like cascading deletes maintain data consistency. All relationships are explicitly defined with appropriate cascade rules.
- **SSL Encryption**: All database connections require SSL/TLS encryption, ensuring that sensitive patient data transmitted between the application and database servers cannot be intercepted or read in transit. Certificate validation ensures connection authenticity.
- **Automated Backups**: Neon PostgreSQL provides continuous backup capabilities with point-in-time recovery, enabling restoration to any moment within the retention period - a critical requirement for healthcare data compliance and disaster recovery planning.

The database schema is normalized to reduce redundancy while being optimized for healthcare-specific query patterns through strategic denormalization where performance demands it. Indexes are carefully designed to support common query patterns without excessive overhead.

3.2 Data Flow Diagrams

Data Flow Diagrams (DFDs) provide a graphical representation of how information moves through the BondHealth platform, illustrating the relationships between external entities,

processes, and data stores. This section describes the three most critical workflows in the system: appointment booking, lab report processing, and payment processing. Each description follows the Gane-Sarson notation with external entities, processes, data stores, and data flows clearly defined.

3.2.1 Appointment Booking Data Flow

The appointment booking process represents one of the most frequently used workflows in the BondHealth platform, enabling patients to schedule consultations with doctors based on real-time availability. The complete data flow encompasses authentication, doctor search, availability checking, appointment creation, notification delivery, and dashboard updates across multiple system components.

Detailed Process Description:

1. **Patient Authentication**: The patient provides login credentials through the login form. The system validates these credentials against the Users data store, comparing the provided password with the stored bcrypt hash. Upon successful authentication, the system generates a JWT token containing user identity and role information, stores it in an HTTP-only cookie, and establishes an authenticated session in the server-side session store. Failed attempts are logged for security monitoring, and multiple failures trigger temporary account lockout.

2. **Doctor Search and Filtering**: The authenticated patient accesses the doctor search interface and applies filters such as specialization, hospital location, availability date, gender preference, languages spoken, and patient ratings. The system queries the Doctors data store, applying the specified filters and returning matching doctor profiles including their consultation fees, qualifications, experience, and available time slots. Results are paginated for performance and sorted by relevance or patient preference.

3. **Real-time Availability Check**: When the patient selects a specific doctor and date, the system queries the Appointments data store to retrieve all existing appointments for that doctor on the selected date. It also checks the Doctor Leave data store to verify the doctor is not on leave during the requested period. The system calculates available time slots by subtracting booked appointments and leave periods from the doctor's configured working hours (stored as `available_days` and `available_time` arrays). This calculation respects appointment duration and buffer times between appointments.

4. **Slot Selection and Booking**: The patient selects an available time slot and provides the reason for visit. The system validates that the slot remains available (preventing double-booking through database transactions with row-level locking), creates a new appointment record in the Appointments data store with status set

to 'pending', and generates a unique appointment UUID and token number. The system also records the timestamp and IP address for audit purposes.

5. **Payment Processing (if applicable)**: For paid consultations, the system initiates the payment workflow, creating a payment record in the Payments data store with status 'pending' and redirecting to the payment gateway. Upon successful payment confirmation via webhook, the appointment status is updated to 'confirmed'. If payment fails, the appointment status remains 'pending' and the patient is notified to retry.

6. **Notification Generation**: The system triggers the Notification Module to send confirmation messages through multiple channels:

   - Email confirmation with appointment details, doctor information, and calendar attachment (.ics file) for easy import
   - SMS reminder with date, time, and location (or video link for telehealth)
   - In-app notification visible on the patient dashboard with action buttons
   - Push notification if the patient has enabled mobile alerts on their device

7. **Dashboard Updates**: The patient's dashboard is updated in real-time to display the new appointment in the "Upcoming Appointments" section. The doctor's dashboard is updated via WebSocket to show the new booking in their schedule with appropriate status indicators. Hospital administrators can view the appointment in their management interface for operational oversight.

Data Stores Involved:

- **Users**: Stores authentication credentials, user profiles, and role information for all system users
- **Patients**: Contains patient-specific data including medical conditions, allergies, and emergency contacts
- **Doctors**: Stores doctor profiles, specializations, consultation fees, and availability patterns
- **Appointments**: Maintains all appointment records with status, dates, times, and reasons for visit
- **Doctor Leave**: Tracks doctor leave periods that affect appointment availability calculations
- **Payments**: Records payment transactions linked to appointments for financial tracking

3.2.2 Lab Report Processing Data Flow

Laboratory technicians use this workflow to process patient test requests, enter results, upload supporting documents, and share reports with doctors and patients according to configured privacy preferences. The workflow ensures that test results are accurately recorded, properly prioritized, and securely delivered to authorized recipients while maintaining a complete audit trail.

Detailed Process Description:

1. **Technician Authentication**: Lab technicians log into the system using their credentials. The authentication middleware verifies the user's role as 'lab' and grants access to lab-specific features. Failed authentication attempts are logged, and account lockouts are triggered after multiple failures. Successful logins record the technician's identity for audit purposes.

2. **Patient Selection**: The technician accesses the patient search interface, which provides multiple lookup methods:

   - Search by patient UUID or medical record number for precise matching
   - Search by name with fuzzy matching to handle spelling variations
   - Browse recent patients from the last 7 days for quick access to repeat patients
   - Scan QR code from patient identification band (if using mobile/tablet interface) for error-free identification

   The system queries the Patients data store and returns matching patient records with basic demographic information for confirmation.

3. **Test Information Entry**: The technician selects the test type from a predefined list of laboratory tests, each with associated normal ranges, units, and required input fields. The system displays appropriate input fields based on test type:

   - Numeric fields with unit selection for quantitative tests (e.g., blood glucose in mg/dL, cholesterol in mmol/L)
   - Text areas for qualitative observations (e.g., urinalysis description, culture results)
   - Multiple choice for categorical results (e.g., positive/negative, reactive/non-reactive, present/absent)
   - Date/time fields for timed measurements (e.g., peak drug levels)

4. **Result Entry and Validation**: The technician enters test results with real-time validation:

   - Range checking against normal values with visual indicators for out-of-range results (highlighted in yellow for abnormal, red for critical)

- Unit consistency verification to prevent unit conversion errors
- Required field completion validation before submission
- Critical value alerts that require confirmation before submission, with mandatory override reason

5. **Priority Assignment**: The technician sets the report priority level, which determines notification urgency and dashboard highlighting:

   - **Normal**: Routine results, standard notification via email and in-app (blue indicator)
   - **Urgent**: Results requiring prompt attention, email + SMS notification with escalation if not viewed (orange indicator)
   - **Critical**: Life-threatening values requiring immediate action, SMS + phone call escalation protocol (red indicator with confirmation required and escalation to on-call staff)

6. **File Upload**: Supporting documents can be attached to the report:

   - PDF reports from laboratory equipment with automatic metadata extraction
   - Images of slides, cultures, or test strips for visual reference
   - Scanned documents from external labs

   The system validates file types (allowed: PDF, JPG, PNG, TIFF), enforces size limits (max 25MB per file), and performs virus scanning before storage. Files are uploaded to AWS S3/Azure Blob storage with encrypted filenames and access controls. Each file receives a unique identifier and is stored with checksums for integrity verification.

7. **Sharing Preferences Configuration**: The technician specifies who can access the report:

   - **Doctor Only**: Report visible only to the requesting doctor (default for most diagnostic tests)
   - **Patient Only**: Report visible only to the patient (rare, used for self-ordered tests or direct-to-consumer results)
   - **Both**: Report visible to both doctor and patient (common for routine results like blood counts)
   - **Referring Physician**: Option to share with additional doctors if specified in the test order

   These preferences are stored in the `shared_with` field and enforced by the access control middleware at both the API and data levels.

8. **Report Submission and Storage**: Upon submission, the system:
   - Creates a new record in the Lab Reports data store with all entered data, including metadata
   - Generates a unique report UUID for external reference and patient communication
   - Updates the report status to 'completed' (or 'pending' if results are partial with follow-up tests)
   - Associates the report with the patient, doctor, and lab technician records for complete traceability
   - Triggers the notification workflow based on priority level and sharing preferences
   - Records the submission timestamp and technician identity in the audit log
9. **Notification Delivery**: The Notification Module sends alerts based on priority and sharing preferences:
   - Doctor receives in-app notification and email with direct link to the report
   - Patient receives notification only if `shared_with` includes 'patient' or 'both', with appropriate privacy messaging
   - Critical results trigger immediate SMS and escalate to on-call protocols with confirmation tracking
   - Report ready notifications include direct links to view/download the report with expiry times for security

3.2.3 Payment Processing Data Flow

The payment processing workflow handles all financial transactions within the BondHealth platform, including appointment fees, consultation charges, and potential refunds. The workflow integrates with external payment gateways while maintaining comprehensive internal records for reconciliation, audit purposes, and financial reporting.

Detailed Process Description:

1. **Payment Initiation**: The payment workflow is triggered in one of several scenarios:
   - Patient books an appointment requiring upfront payment (common for private consultations)
   - Patient completes a consultation and is billed afterward (post-paid model)
   - Patient pays an outstanding invoice from their account (settling balances)
   - Admin processes a refund for a cancelled appointment (financial adjustment)

   The system creates a payment record in the Payments data store with initial status 'pending' and generates a unique payment UUID for tracking.

2. **Amount Calculation**: The system calculates the total amount due:
   - Base consultation fee from the doctor's profile (may vary by appointment type)
   - Applicable taxes (GST/VAT configured by hospital location)
   - Any discounts or insurance adjustments (promotional codes, insurance coverage)
   - Previous outstanding balances if applicable (consolidated billing)

   The detailed breakdown is displayed to the patient for confirmation before proceeding.

3. **Payment Method Selection**: The patient selects from available payment methods:
   - **Credit/Debit Card**: Integrated with Stripe/Razorpay for secure card processing using tokenization
   - **Insurance Billing**: Captures insurance information for later processing and claim submission
   - **Cash**: Records cash payment with receipt generation (primarily for in-person visits)
   - **Digital Wallets**: Support for Apple Pay, Google Pay, and local wallet solutions
   - **UPI/Bank Transfer**: Region-specific payment methods (India, Southeast Asia)

4. **Payment Gateway Integration**: For card and digital wallet payments, the system:
   - Creates a payment intent with the gateway using their API, specifying amount, currency, and metadata
   - Receives a client secret for front-end tokenization (PCI compliance maintained by never handling raw card details)
   - Implements 3D Secure authentication if required by the card issuer for additional security
   - Handles asynchronous responses through webhooks for reliable processing

5. **Transaction Processing**: The gateway processes the payment and returns:
   - Success response with transaction ID, authorization code, and timestamp
   - Failure response with error codes and reasons (insufficient funds, card declined, etc.)
   - Pending status for transactions under review (fraud checks, manual review)

   The system updates the payment record with the transaction ID and current status, and logs the outcome.

6. **Post-Payment Processing**: Upon successful payment:

- Appointment status is updated to 'confirmed' (if payment was for booking)
- Invoice is generated as PDF with all required details (hospital info, patient details, itemized charges, taxes)
- Invoice is stored in cloud storage and URL saved to payment record
- Receipt is emailed to the patient with the invoice attached
- Payment confirmation is displayed to the patient with transaction reference
- Accounting records are updated for hospital financial systems (automated journal entries)

7. **Refund Processing**: When cancellations occur, administrators can process refunds:
   - Admin initiates refund through interface with reason selection (patient cancellation, duplicate payment, etc.)
   - System validates refund eligibility based on cancellation policy and time elapsed
   - Refund request is sent to payment gateway via API with appropriate parameters
   - Gateway processes refund and returns confirmation with refund transaction ID
   - Payment record is updated with refund status, reference, and timestamp
   - Patient receives refund confirmation via email with credit note if applicable
8. **Webhook Handling**: The system implements webhook endpoints for asynchronous gateway notifications:
   - Payment success/failure updates for transactions that were pending
   - Dispute notifications when customers challenge charges
   - Refund confirmations when gateway processes refunds
   - Settlement reports for daily reconciliation

   Webhooks update internal payment records and trigger appropriate business processes (e.g., marking appointments confirmed).

3.3 Use Case Diagrams

Use case diagrams capture the functional requirements of the BondHealth platform from the perspective of different user roles, illustrating the interactions between actors and the system. Each use case represents a discrete unit of functionality that provides value to the user. This section describes all use cases for the four primary actor types: Patients, Doctors, Hospital Administrators, and Laboratory Technicians.

3.3.1 Patient Use Cases

Patients are the primary beneficiaries of the BondHealth platform, accessing a comprehensive suite of features designed to manage their healthcare journey from registration through treatment and follow-up. The patient use cases encompass all interactions that patients can perform within the system, organized into functional categories for clarity.

Complete List of Patient Use Cases:

1. **Account Registration and Management**:
   - Register new account with email verification and phone confirmation
   - Login to system with username/password or biometric options
   - Logout from system with session termination
   - Reset forgotten password via email with secure tokens
   - Update profile information including contact details and preferences
   - Manage emergency contacts with relationship and priority
   - Configure notification preferences per channel (email, SMS, push)
   - Delete account with data export option (GDPR compliance)
2. **Profile and Health Information**:
   - View personal profile summary with quick access to key information
   - Update demographic information (address, phone, insurance details)
   - Add/edit medical conditions with ICD-10 coding for accuracy
   - Add/edit allergies with severity levels and reaction descriptions
   - Upload insurance information including policy numbers and coverage
   - View medical history timeline with chronological organization
   - Download complete medical record as PDF for sharing with other providers
3. **Doctor Discovery and Selection**:
   - Browse doctors by specialization with filtering options
   - Search doctors by name, hospital, or location with autocomplete
   - Filter doctors by availability, ratings, gender, languages, and accepted insurance
   - View doctor profiles with qualifications, experience, patient reviews, and fees
   - Read patient reviews and ratings with verification badges
   - Check doctor availability calendar with real-time slot visibility
   - Save favorite doctors for quick access to future appointments
4. **Appointment Management**:

- Book new appointment with selected doctor and preferred time
- Select preferred date and time from available slots with visual indicators
- Specify reason for visit with structured templates (new, follow-up, urgent)
- View all upcoming appointments in chronological order with countdown
- View past appointment history with visit summaries and notes
- Reschedule existing appointment with reason tracking and availability check
- Cancel appointment with reason and confirmation
- Add appointment to personal calendar (Google, Apple, Outlook) with one click
- Set appointment reminders with configurable timing

5. **Medical Records Access**:
    - View all lab reports with test details and reference ranges
    - Filter reports by date range, test type, ordering doctor
    - Download report PDFs for offline access or sharing
    - Share reports with other healthcare providers via secure link
    - View report trends over time with graphical visualization (for recurring tests)
    - Access radiology images and reports with zoom and measurement tools
    - View vaccination records with due dates for boosters
6. **Prescription Management**:
    - View active prescriptions with medicine details and dosage instructions
    - View prescription history including expired and completed medications
    - Request prescription refill with automatic doctor notification
    - Download prescription PDF for pharmacy use
    - Set medicine reminders with dosage schedules and adherence tracking
    - View medication history with start/end dates and prescriber information
    - Receive refill reminders before medication runs out (configurable days before)
7. **Payment and Billing**:
    - Make payment for appointments using preferred payment method
    - View payment history with transaction details and status
    - Download invoices and receipts for reimbursement or records
    - Save payment methods for future use with tokenization
    - Request refunds for cancelled appointments with automatic eligibility check

- View outstanding balances and due dates
- Set up auto-pay for recurring appointments or subscriptions

8. **Communication**:
   - Chat with doctors securely with message history and attachment support
   - Receive notifications for all relevant events (appointment reminders, report ready)
   - View message history with search and filtering capabilities
   - Send files and images in chat (symptoms photos, previous reports)
   - Receive broadcast messages from hospital (announcements, health tips)
   - Provide feedback and ratings after consultations with detailed comments
9. **Health Management**:
   - Set health reminders (medication, checkups, screenings)
   - Track vital signs if integrated with wearables (optional feature)
   - Complete pre-visit questionnaires before appointments
   - View health tips and educational content personalized to conditions
   - Manage family member accounts for dependents (children, elderly parents)

3.3.2 Doctor Use Cases

Doctors utilize the BondHealth platform to manage their clinical workflow efficiently, accessing patient information, recording observations, prescribing medications, and communicating with patients. The doctor use cases are designed to minimize administrative overhead while maximizing time available for direct patient care.

Complete List of Doctor Use Cases:

1. **Account and Profile Management**:
   - Login to system with secure credentials and optional 2FA
   - Update professional profile including bio and clinical interests
   - Modify consultation fees for different appointment types
   - Update availability schedule (working days, hours, and break times)
   - Upload/change profile photo for patient recognition
   - Add/update qualifications and certifications with verification
   - Set consultation modes (in-person, video, both) with availability per mode
   - Configure notification preferences for different event types
2. **Dashboard Overview**:

- View personalized dashboard with summary cards and key metrics
- See today's appointment count and schedule with time blocks
- View pending lab reports count with priority breakdown
- Check unread messages count with previews
- Monitor upcoming leave status and approval state
- View patient statistics (total patients, new patients this week)
- Access quick actions for common tasks (prescribe, view reports)

3. **Appointment Management**:
   - View today's complete schedule with detailed time slots and patient info
   - View upcoming appointments for future dates with filtering
   - View appointment history with past patients and visit reasons
   - Start consultation for each appointment, recording start time
   - Mark patient as arrived/checked-in for in-person visits
   - Complete consultation and close appointment with summary notes
   - View patient wait times and queue status for clinic flow management
   - Block time slots for personal reasons or administrative tasks
4. **Patient Management**:
   - View complete patient list with pagination and sorting options
   - Search patients by name, ID, or contact with fuzzy matching
   - Filter patients by recent visits, conditions, or demographics
   - Access patient medical history with timeline visualization
   - View past consultations with complete notes and diagnoses
   - See patient demographics and emergency contacts for reference
   - Add patients to favorites for quick access to frequent visitors
   - View patient visit timeline with clinical events in order
5. **Lab Report Management**:
   - View pending lab reports queue with count and priority indicators
   - Filter reports by priority (normal/urgent/critical) and date
   - View complete report details with results, reference ranges, and flags
   - Add clinical findings and interpretations to reports
   - Correlate results with patient history and previous values

- Flag abnormal results for follow-up or discussion
- Request additional tests if needed based on findings
- Mark reports as reviewed with timestamp for audit
- Download or print reports for physical records

6. **Prescription Management**:
   - Create new prescriptions with medicine selection from hospital formulary
   - Select medicines with dosage suggestions and common prescriptions
   - Specify dosage, frequency, and duration with standardized options
   - Add special instructions for patient (e.g., "take with food")
   - Set prescription validity period and refill limits
   - Renew existing prescriptions with one-click and date adjustment
   - View patient's active medications to avoid conflicts
   - Check for drug interactions automatically (integrated database)
   - Print or email prescription to patient with pharmacy options
   - Add digital signature for authenticity
7. **Leave Management**:
   - Apply for leave with date range and reason selection
   - Specify reason for leave (vacation, conference, sick)
   - View leave balance if tracked by hospital policy
   - Check leave approval status in real-time
   - Cancel pending leave requests if plans change
   - View upcoming approved leaves on calendar
   - Set auto-reply for leave periods with alternative contact
8. **Communication**:
   - Chat with patients securely with end-to-end encryption
   - View message history with each patient organized by date
   - Send file attachments (images, PDFs) for reference
   - Receive notifications for new messages with preview
   - Send broadcast messages to multiple patients (announcements)
   - Conduct video consultations if integrated (telehealth)
   - Share educational materials with patients (articles, videos)

9. **Clinical Documentation**:
   - Write consultation notes with templates for efficiency
   - Create diagnosis records with ICD-10 codes for billing
   - Document treatment plans with follow-up schedule
   - Record vital signs measurements during consultations
   - Generate referral letters to specialists with patient context
   - Complete medical certificates with digital signature
   - Maintain procedure notes for any in-office procedures

3.3.3 Admin Use Cases

Hospital administrators oversee the operational aspects of the BondHealth platform, managing users, inventory, and system configuration. The admin use cases provide comprehensive tools for hospital management, ensuring smooth operation of all healthcare services and enabling data-driven decision making.

Complete List of Admin Use Cases:

1. **Hospital Management**:
   - Register new hospital/profile with all required details
   - Update hospital information (address, contact, facilities)
   - Manage hospital departments with heads and staff
   - Configure hospital working hours and holiday schedule
   - Set hospital policies (cancellation, refund, visit duration)
   - Manage hospital locations/branches with individual settings
   - Upload hospital logos and branding for patient-facing materials
   - Configure tax rates and currency settings per location
2. **Doctor Management**:
   - Add new doctors to the system with complete profile
   - Verify doctor credentials and licenses with document upload
   - Assign doctors to departments and specializations
   - Set doctor consultation fees for different appointment types
   - Configure doctor schedules with recurring patterns
   - Edit doctor profiles as needed for updates
   - Deactivate/reactivate doctor accounts for leaves or separation
   - View doctor performance metrics (patients seen, ratings, revenue)

- Manage doctor leave approvals with calendar view
- Handle doctor resignation/termination with patient reassignment

3. **Patient Management**:
   - View all patient registrations with demographic filters
   - Search patients by various criteria (name, ID, phone, email)
   - Assist with patient account issues (password reset, unlocking)
   - Merge duplicate patient records with data preservation
   - Manage patient data access requests for compliance
   - Handle patient complaints with tracking and resolution
   - Export patient data for reporting or migration
4. **Lab Technician Management**:
   - Add new lab technicians with credentials and qualifications
   - Assign technicians to labs/departments based on expertise
   - Manage technician roles and permissions within lab module
   - View technician workload and performance metrics
   - Deactivate technician accounts as needed
   - Manage technician schedules and shift assignments
5. **Department and Specialization Management**:
   - Create new medical departments with descriptions
   - Add specializations under departments with standard codes
   - Assign doctors to specializations with primary/secondary
   - Configure department-specific settings (consultation duration, fees)
   - Manage department heads with reporting relationships
   - View department performance metrics (volume, revenue, satisfaction)
6. **Medicine Inventory Management**:
   - Add new medicines to inventory with complete details
   - Update medicine quantities with adjustment reasons
   - Set reorder levels and automatic alerts
   - Track expiry dates with notification before expiry
   - Manage medicine pricing with retail and insurance rates
   - View inventory reports with usage patterns and forecasts

- Process medicine requisitions from departments
- Manage suppliers and purchase orders with tracking
- Track medicine usage patterns for procurement planning

7. **Appointment Oversight**:
   - View all appointments across hospital with comprehensive filters
   - Filter appointments by status, doctor, date, department
   - Handle appointment conflicts with resolution tools
   - View no-show reports with patient history
   - Monitor appointment utilization (fill rates, cancellations)
   - Generate appointment analytics with visual dashboards
   - Manage waitlist for popular slots with auto-assignment
8. **Leave Management**:
   - View all leave requests with status and details
   - Filter by status (pending, approved, rejected) for workflow
   - Approve or reject leave requests with comment capability
   - View leave calendar showing coverage across departments
   - Manage leave policies and balances per employee
   - Generate leave reports for HR and planning
   - Handle emergency leave situations with override
9. **Financial Management**:
   - View revenue reports with daily, weekly, monthly summaries
   - Monitor payment collections by method and status
   - Process refunds with approval workflow
   - View outstanding payments and aging reports
   - Generate financial statements (P&L, balance sheet)
   - Manage insurance claims with tracking and follow-up
   - Configure payment gateway settings and fee structures
   - Reconcile transactions with bank statements
10. **Reporting and Analytics**:
    - Generate operational reports (appointments, utilization, wait times)
    - View dashboard statistics with real-time updates

- Export data for external analysis in various formats
- Monitor key performance indicators with trend charts
- Track patient satisfaction metrics from feedback
- Analyze appointment trends for capacity planning
- View doctor performance analytics with comparisons
- Generate compliance reports for regulatory requirements

11. **System Configuration**:
    - Manage user roles and permissions with granular controls
    - Configure notification templates for all channels
    - Set system parameters (timeouts, limits, defaults)
    - Manage audit logs with search and export
    - Configure integration settings for third-party services
    - Perform system backups and test restoration
    - Monitor system health and performance metrics

3.3.4 Lab Technician Use Cases

Laboratory technicians have specialized use cases focused on test processing, result entry, and report management. These use cases are designed to streamline laboratory workflows while maintaining accuracy, quality control, and efficient communication with requesting doctors.

Complete List of Lab Technician Use Cases:

1. **Account Management**:
    - Login to system with secure credentials and role verification
    - Update personal profile (contact details, preferences)
    - Change password with security requirements
    - View dashboard with work summary and daily statistics
    - Logout from system with session cleanup
2. **Dashboard Overview**:
    - View today's test statistics (total, completed, pending)
    - See pending reports count with priority breakdown
    - View completed reports count for the day
    - Monitor urgent/critical cases requiring immediate attention

- Check workload distribution across technicians
- View recent activity with timestamps
- Access quick actions for common tasks (new report, search)

3. **Patient Management**:
   - Search for patients by ID, name, or contact with multiple criteria
   - View patient demographics for identification
   - Access patient test history for context
   - View previous test results for comparison
   - Verify patient identity before testing (name, DOB, ID)
   - Add new patient if authorized (emergency or walk-in)
   - Update patient contact information if provided
4. **Lab Report Creation**:
   - Create new lab report with automatic ID generation
   - Select patient from search results with confirmation
   - Choose test type from standardized list with categories
   - Enter test date and time (defaults to now)
   - Add ordering/referring doctor from search
   - Enter test results with appropriate input fields
   - Add qualitative observations and interpretations
   - Upload supporting files (PDFs, images) with validation
   - Set report priority (normal/urgent/critical) with impact explanation
   - Configure sharing preferences (doctor/patient/both)
   - Add comments or notes for internal use
   - Save draft for later completion if interrupted
5. **Result Entry and Validation**:
   - Enter numerical results with unit selection from predefined options
   - Receive real-time validation against reference ranges
   - Get alerts for out-of-range values with severity indication
   - Confirm critical values before submission with override reason
   - Enter qualitative results from standardized dropdowns
   - Add free-text interpretations and clinical correlations

- Flag abnormal results for attention with color coding
- Correlate results with previous tests for trending

6. **File Management**:
   - Upload report files (PDF, images) with drag-and-drop
   - Preview uploaded files before finalizing
   - Replace/update files if errors detected
   - Delete incorrect attachments with confirmation
   - View file upload history with versions
   - Ensure file naming follows conventions automatically
   - Verify file readability and quality indicators
7. **Report Management**:
   - View all created reports with filters and sorting
   - Filter reports by status (draft, pending, completed, reviewed)
   - Search reports by patient, date, test type, priority
   - Edit pending reports with version tracking
   - Submit completed reports with final review
   - View report details in comprehensive format
   - Print reports with configured layouts
   - Download reports as PDF for distribution
   - Resend reports if delivery failed
   - Track report delivery status (viewed by doctor/patient)
8. **Quality Control**:
   - Verify results against quality standards and controls
   - Document any quality issues or deviations
   - Flag results requiring re-testing with reasons
   - Participate in proficiency testing records
   - Maintain equipment logs if integrated
   - Record reagent lots and expiry dates for traceability
9. **Communication**:
   - Receive notifications for new test requests
   - Send alerts for critical results with confirmation

- Communicate with doctors about results or issues
- Receive feedback on report quality and timeliness
- Participate in lab team communications (announcements)

10. **Workflow Management**:
    - Prioritize work based on urgency and received time
    - Manage test queue with drag-and-drop prioritization
    - Track turnaround times for performance monitoring
    - Hand off work to next shift with notes
    - Report equipment issues with ticketing
    - Request supplies when low

3.4 Database Schema Design (Neon PostgreSQL)

The BondHealth platform utilizes Neon PostgreSQL, a serverless PostgreSQL solution that provides automatic scaling, high availability, and connection pooling optimized for modern cloud applications. The database design implements healthcare industry best practices including UUID primary keys for distributed uniqueness, array data types for efficient multi-value storage, and comprehensive foreign key constraints for referential integrity. SSL connections are enforced for all database communications, ensuring data security in transit and compliance with healthcare data protection regulations such as HIPAA and GDPR.

Database Design Principles:

- **Normalization**: The schema follows third normal form (3NF) to eliminate data redundancy while maintaining efficient query performance through strategic indexing. This balance ensures data integrity without sacrificing speed for common queries.
- **Data Integrity**: Foreign key constraints with appropriate cascade rules ensure that related data remains consistent across all tables. Cascading deletes are used judiciously where appropriate (e.g., removing patient data when user is deleted), while restrict rules prevent accidental data loss in other relationships.
- **Audit Capabilities**: `created_at` and `updated_at` timestamps on all tables provide audit trails for regulatory compliance and debugging. Additional audit tables track changes to sensitive data for forensic analysis.
- **Performance Optimization**: Strategic indexes on frequently queried columns ensure rapid data retrieval even as the database scales to millions of records. Composite indexes support complex queries with multiple conditions.

- **PostgreSQL-Specific Features**: Leveraging array data types for multi-value attributes, JSON fields where flexible schemas are beneficial, and full-text search capabilities for enhanced search functionality across patient records and doctor profiles.

The following tables form the core of the BondHealth database schema, each designed with specific healthcare requirements in mind.

Database Indexes for Performance Optimization:

To ensure optimal query performance as the database grows to millions of records, the following indexes have been created on frequently queried columns. These indexes significantly reduce query execution time by allowing the database to quickly locate relevant rows without scanning entire tables.

- `CREATE INDEX idx_users_email ON users(email);` - Accelerates login and user lookup by email, one of the most frequent operations
- `CREATE INDEX idx_users_username ON users(username);` - Speeds up login by username for users who prefer username authentication
- `CREATE INDEX idx_patients_user_id ON patients(user_id);` - Fast patient profile access from user ID during authentication
- `CREATE INDEX idx_doctors_hospital_id ON doctors(hospital_id);` - Quick doctor lookup by hospital for directory features
- `CREATE INDEX idx_doctors_specialization ON doctors(specialization);` - Enables fast doctor filtering by specialty for patient searches
- `CREATE INDEX idx_appointments_patient_id ON appointments(patient_id);` - Rapid retrieval of patient appointment history for dashboards
- `CREATE INDEX idx_appointments_doctor_id ON appointments(doctor_id);` - Fast doctor schedule access for availability checking
- `CREATE INDEX idx_appointments_date ON appointments(appointment_date);` - Optimizes date-based queries for daily schedules and reports
- `CREATE INDEX idx_lab_reports_patient_id ON lab_reports(patient_id);` - Quick patient report history access for medical records
- `CREATE INDEX idx_lab_reports_status ON lab_reports(status);` - Enables fast filtering by report status for lab dashboards
- `CREATE INDEX idx_prescriptions_patient_id ON prescriptions(patient_id);` - Rapid prescription history retrieval for patient records
- `CREATE INDEX idx_messages_sender_receiver ON messages(sender_id, receiver_id);` - Optimizes chat conversation queries for message history

- `CREATE INDEX idx_messages_created_at ON messages(created_at DESC);` - Speeds up message history display in chronological order

3.5 API Design (RESTful Endpoints)

The BondHealth platform implements a comprehensive RESTful API architecture that follows industry best practices for web service design. All endpoints adhere to REST conventions with appropriate HTTP methods, consistent resource naming, and standardized response formats. The API is designed to be intuitive, self-documenting, and maintainable while ensuring security through authentication middleware and role-based access controls.

API Design Principles:

- **Resource-Oriented**: Endpoints are organized around resources (patients, doctors, appointments) rather than actions, making the API intuitive and consistent with REST philosophy.
- **Consistent Naming**: Plural nouns for collections (/appointments) and singular for specific resources (/appointments/{id}) provide clear and predictable URL patterns.
- **HTTP Methods**: GET for retrieval, POST for creation, PUT for full updates, PATCH for partial updates, DELETE for removal - each method has a specific, well-defined purpose.
- **Status Codes**: Appropriate HTTP status codes (200 OK, 201 Created, 400 Bad Request, 401 Unauthorized, 403 Forbidden, 404 Not Found, 500 Internal Server Error) provide clear feedback about operation outcomes.
- **Versioning**: API versioning through URL path (/api/v1/...) supports future changes without breaking existing clients.
- **Response Format**: Consistent JSON structure with success/data/error fields makes client-side handling predictable and straightforward.
- **Authentication**: JWT tokens in HTTP-only cookies for all protected endpoints, ensuring secure, automatic token handling.
- **Rate Limiting**: Configurable rate limits per endpoint prevent abuse and ensure fair resource allocation across all users.

The following tables document all API endpoints organized by functional area. Each endpoint includes the HTTP method, URL path, description, and access level required.

3.6 Module-wise Detailed Design

This section provides comprehensive design specifications for each major module of the BondHealth platform, describing their internal architecture, component structure, key features, and interactions with other modules. Each module is designed with high cohesion and low coupling, following software engineering best practices to ensure maintainability, testability, and scalability. The modular architecture allows independent development, deployment, and scaling of different functional areas based on usage patterns.

3.6.1 Authentication Module

The authentication module is the security gateway for the BondHealth platform, responsible for verifying user identities, managing sessions, and enforcing access controls. It implements industry-standard security practices while maintaining usability through seamless token management and session handling.

Core Components:

1. **JWT Token Service**: Generates and validates JSON Web Tokens with the following characteristics:
   - Tokens contain user ID, username, role, and session ID in the payload for stateless authorization
   - Signed with HS256 algorithm using a secure server-side secret stored in environment variables
   - Expiration set to 7 days for access tokens (configurable based on security requirements)
   - Refresh token mechanism with 30-day validity for extending sessions without re-login
   - Token versioning (increment on password change) to support forced logout of all sessions
2. **HTTP-Only Cookie Management**: Tokens are stored in HTTP-only cookies with comprehensive security flags:
   - `HttpOnly`: Prevents JavaScript access, eliminating XSS token theft vectors
   - `Secure`: Ensures cookies only sent over HTTPS connections, preventing network interception
   - `SameSite=Strict`: Protects against CSRF attacks by restricting cross-origin requests
   - `Max-Age`: Sets cookie expiration matching token lifetime for automatic cleanup
   - Path restriction to API endpoints only, minimizing exposure

3. **Server-Side Session Store**: Maintains active sessions in memory with Redis backing for distributed deployments:
   - Key: session ID (from JWT) for O(1) lookup performance
   - Value: user ID, creation time, last activity, IP address, user agent for security monitoring
   - Enables forced logout of specific sessions from admin panel
   - Session invalidation on password change, account lock, or admin action
   - Concurrent session limiting (configurable, default 5 per user) to prevent abuse
4. **Password Hashing Service**: Implements bcrypt with configurable work factor:
   - Salt rounds: 10 (balance of security and performance, approximately 100ms per hash)
   - Automatic salt generation and storage with hash for password verification
   - Constant-time comparison to prevent timing attacks on password verification
   - Password complexity validation (minimum 8 chars, mixed case, numbers, special) before hashing
5. **Authentication Middleware Pipeline**:
   - Extract token from cookies (or Authorization header for API clients)
   - Verify token signature and expiration using JWT library
   - Validate session existence in session store (prevents use of revoked tokens)
   - Attach user object to request for downstream use in controllers
   - Refresh token if approaching expiration (sliding sessions) for active users
   - Log authentication attempts (success/failure) for security monitoring and audit
6. **Role-Based Access Control (RBAC) Middleware**:
   - Check user.role against required roles for endpoint (array of allowed roles)
   - Hierarchical role support (admin can access doctor endpoints, but not vice versa)
   - Permission-based checks for fine-grained control beyond basic roles
   - Hospital-scoped access for multi-tenant isolation (doctors only see their hospital's data)

Authentication Flow:

1. User submits credentials via login form (username/email + password) over HTTPS
2. Server validates credentials against database:

- Look up user by username/email with case-insensitive matching
- Compare provided password with stored hash using bcrypt's constant-time comparison
- Check account status (active, not locked, email verified)
- Record failed attempts in database and implement rate limiting (5 attempts, 15-minute lockout)

3. On successful validation:
   - Generate JWT with user payload (user_id, username, role) and unique session ID
   - Create session record in active sessions store with metadata (IP, user agent)
   - Set HTTP-only cookie with token and security flags
   - Update last_login timestamp in database for audit
   - Return user profile (sanitized, no password hash) and role-specific redirect URL
4. On failed validation:
   - Increment failed attempt counter for the user
   - Return 401 Unauthorized with generic error message (not revealing whether username or password was incorrect)
   - After threshold exceeded, lock account and notify user via email
5. Subsequent requests include token in cookie automatically by browser
6. Authentication middleware validates token and session on every protected request
7. Role-based middleware checks permissions before processing request
8. Access granted with user context or denied with appropriate HTTP status

3.6.2 Patient Dashboard Module

The patient dashboard provides a comprehensive, intuitive interface for patients to manage all aspects of their healthcare journey. It aggregates information from multiple modules and presents it in a unified view optimized for quick access and clear understanding, following healthcare UX best practices for readability and accessibility.

Component Architecture:

1. **Profile Summary Card**:
   - Displays patient name, photo (if available), blood type, and age calculated from DOB

- Shows emergency contact information prominently with one-tap dialing on mobile
- Includes quick edit button for profile updates (opens modal with editable fields)
- Displays insurance information summary (provider, policy number, coverage dates)
- Shows account status and verification badges (email verified, phone verified)

2. **Upcoming Appointments Section**:
   - Lists next 3-5 upcoming appointments with date, time, doctor name, and specialty
   - Each entry includes action buttons: Reschedule, Cancel, View Details
   - Color-coded status indicators (confirmed in green, pending payment in yellow)
   - Countdown timer showing time until appointment (days/hours)
   - Video call join button for telehealth appointments (active 15 minutes before)
   - Option to add to calendar (Google, Apple, Outlook) with one-click .ics file
3. **Past Appointments Section**:
   - Paginated list of completed appointments with expandable details
   - Filter by date range, doctor, specialty for easy lookup
   - Each entry links to consultation summary and doctor's notes
   - Option to book follow-up appointment with same doctor (pre-filled details)
   - Feedback and rating interface for completed visits (star rating + comments)
4. **Medical Records Section**:
   - Tabbed interface for different record types with clear organization:
     - **Lab Reports**: List with test type, date, status (new/reviewed), download button
     - **Prescriptions**: Active and historical prescriptions with refill status and remaining refills
     - **Imaging**: X-rays, MRIs, CT scans with viewer links and radiology reports
     - **Vaccinations**: Record of immunizations with due dates for boosters
     - **Documents**: Uploaded medical documents (advanced directives, consent forms)
   - Search and filter capabilities across all records with full-text search
   - Timeline view showing chronological medical history with visual timeline
   - Download all records option (ZIP export) for data portability

5. **Prescription Management Area**:
   - Active prescriptions with medicine name, dosage, frequency, and duration
   - Refill status (refills remaining) and days until expiration
   - "Request Refill" button for eligible prescriptions with one-click action
   - Medication reminder settings integration (set daily reminders)
   - Drug interaction warnings displayed prominently if applicable
6. **Quick Action Buttons**:
   - Book New Appointment (opens doctor search modal)
   - Message My Doctor (opens chat with recent doctors list)
   - View Lab Reports (jumps to reports section with filters)
   - Pay Outstanding Bills (opens payment page with due amounts)
   - Find Nearby Hospitals (location-based search with map)
   - Emergency Contact (one-tap dialing for emergency numbers)
7. **Notification Center**:
   - Recent notifications with read/unread status and timestamps
   - Appointment reminders with confirm/decline actions
   - Lab report ready alerts with direct link to view
   - Prescription refill reminders with request button
   - System announcements from hospital administration
   - Mark all as read functionality and notification preferences link
8. **Health Metrics Widget** (optional integration):
   - Recent vital signs if connected to wearables (heart rate, blood pressure, steps)
   - Medication adherence tracking with calendar view
   - Appointment adherence statistics (show/no-show history)
   - Health goals progress with visual indicators

Data Flow:

- Dashboard loads by making parallel API calls to multiple endpoints for performance:
  - GET /api/patient for profile (includes medical conditions and emergency contacts)
  - GET /api/appointments?status=upcoming&limit=5 for upcoming appointments

  - GET /api/reports?limit=5&status=new for recent reports with new flag
  - GET /api/prescriptions?status=active for active prescriptions with refill info
  - GET /api/messages/unread/count for notification badge count

- Data is cached client-side with appropriate invalidation strategies (5-minute cache for non-critical data)
- Real-time updates via WebSocket for appointment changes and new messages
- Lazy loading for sections below the fold to improve initial load time
- Error boundaries for each component to prevent total dashboard failure if one API fails

3.6.3 Doctor Dashboard Module

The doctor dashboard is designed for clinical workflow efficiency, providing quick access to today's schedule, patient information, and pending tasks. The interface prioritizes information density while maintaining clarity and ease of use, following clinical workflow patterns familiar to healthcare providers.

Component Architecture:

1. **Dashboard Header**:
   - Welcome message with doctor name and greeting based on time of day
   - Current date and time with timezone indication
   - Quick stats: today's patient count (completed/remaining), pending reports count, unread messages
   - Profile quick-access dropdown with settings, schedule, logout
   - Status toggle (Available/Busy/Offline) affecting appointment availability display
2. **Today's Schedule Component**:
   - Chronological list of today's appointments with clear time slots
   - Each appointment card shows comprehensive information:
     - Time slot with duration and color-coded status (on time, delayed, completed)
     - Patient name, age, and brief reason for visit (chief complaint)
     - Appointment type icon (in-person/video) for quick identification
     - Status indicator (checked-in, waiting, in-progress, completed, no-show)
     - Wait time since scheduled time for delayed appointments (highlighted in red)

- Action buttons per appointment in consistent layout:
  - Start Consultation (opens patient record in modal with all clinical tools)
  - View History (quick popup of previous visits with diagnoses and prescriptions)
  - Message Patient (opens chat sidebar with patient context)
  - Mark No-Show (with reason selection and automatic follow-up)
- Color coding for delayed appointments (yellow after 5 min, red after 15 min)
- Drag-and-drop for manual rescheduling within same day (with confirmation)

3. **Patient List Sidebar**:
   - Searchable list of all patients under doctor's care with instant search
   - Quick filters: recent (last 7 days), frequent (top 10), new (first visit)
   - Each entry shows patient name, last visit date, next appointment (if any)
   - Hover preview of recent activity (last diagnosis, pending tasks)
   - Click to open full patient record in main view with context preservation
4. **Lab Reports Queue**:
   - Priority-based organization with clear visual hierarchy:
     - **Critical (red)**: Requires immediate attention - results outside critical thresholds
     - **Urgent (orange)**: Review within 24 hours - abnormal but not critical
     - **Normal (blue)**: Routine review - within normal ranges
   - Each report card shows key information:
     - Patient name and age for identification
     - Test type and collection date
     - Key results with abnormal values highlighted and flagged
     - Time since report availability with aging indicator
   - One-click action to add findings (opens findings entry modal with template)
   - Bulk actions for normal reports (mark all as reviewed)
5. **Prescription Writing Interface**:
   - Medicine search with auto-complete from hospital formulary (including alternatives)
   - Common dosage templates for quick selection (e.g., "500mg twice daily")
   - Frequency picker with common options (daily, twice daily, every 8 hours, as needed)

- Duration calculator with start/end dates and refill count
- Drug interaction checker integration (real-time checking as medicines added)
- Allergy alert system (warns if prescribed medicine conflicts with patient allergies)
- Digital signature capture with timestamp for legal validity
- Print/email prescription options with pharmacy selection

6. **Leave Management Widget**:
   - Upcoming leave summary with dates and approval status
   - Apply for leave button (opens form with date picker and reason dropdown)
   - Leave balance display (if tracked by hospital policy)
   - Pending requests status with expected approval timeline
7. **Quick Statistics Cards**:
   - Total patients seen today with comparison to average
   - Average consultation time with trend indicator
   - Pending reports count with priority breakdown
   - Unread messages count with preview of latest
   - Patient satisfaction rating (if feedback available)

Workflow Integration:

- Clicking "Start Consultation" opens patient record in a modal with contextual tabs:
  - **Patient Info**: Demographics, conditions, allergies, emergency contacts with visual alerts
  - **Medical History**: Past consultations, diagnoses, procedures in timeline view
  - **Lab Results**: All reports organized by date with trend visualization for repeated tests
  - **Prescriptions**: Active and past medications with adherence tracking if available
  - **Notes**: Consultation notes entry area with templates and voice-to-text option
  - **Billing**: Payment status and history, insurance information
- Real-time updates for new lab reports and messages via WebSocket (toast notifications)
- Auto-refresh of schedule every 5 minutes (configurable) with visual indicator of refresh
- Keyboard shortcuts for power users (Ctrl+N for new prescription, Ctrl+S for save)

3.6.4 Admin Dashboard Module

The admin dashboard provides hospital administrators with comprehensive tools for managing the entire healthcare facility operations. It consolidates data from all modules and presents actionable insights through visual analytics and management interfaces, enabling data-driven decision making and operational efficiency.

Component Architecture:

1. **Statistics Cards Row**:
   - **Total Doctors**: Active/inactive breakdown with click-through to doctor list
   - **Today's Appointments**: Count with comparison to yesterday (percentage change)
   - **Pending Approvals**: Leave requests, doctor registrations, pending verifications
   - **Inventory Status**: Low stock count, expiring medicines (next 30 days)
   - **Revenue Today/Month**: Financial snapshot with currency formatting
   - **Patient Registrations**: New patients today/this week with trend
   - **Lab Tests Pending**: Count by priority (normal/urgent/critical)

   Each card includes trend indicators (up/down arrows) and sparkline charts for quick visualization of historical patterns.

2. **Quick Action Cards Grid**:
   - Add New Doctor (opens multi-step registration form with credential upload)
   - Add Medicine to Inventory (opens form with barcode scanning option)
   - Add Lab Technician (opens registration form with role selection)
   - View All Appointments (opens appointment overview with filters)
   - Generate Reports (opens report builder with template selection)
   - Manage Leave Requests (opens leave management view with calendar)
   - View Financial Summary (opens financial dashboard with charts)
   - System Settings (opens configuration panel with tabs)

   Each card includes icon, description, and one-click access with keyboard shortcuts.

3. **Doctor Management Interface**:
   - Searchable/filterable table of all doctors with server-side pagination
   - Columns: Name, Specialization, Department, Status (active/on leave/inactive), Patient Count, Rating, Actions

- Inline editing for quick updates (status, department, fees)
- Bulk actions for status changes (activate/deactivate selected)
- Credential verification workflow with document upload and expiry tracking
- Document upload for licenses and certifications with expiration alerts
- Schedule management view (weekly calendar with working hours)
- Performance metrics integration (patients seen, ratings, revenue)

4. **Medicine Inventory Management**:
   - Real-time stock levels with visual indicators (green: adequate, yellow: low, red: critical)
   - Low stock alerts with reorder suggestions based on usage patterns
   - Expiry tracking with color-coded warnings (yellow: 3 months, red: 1 month)
   - Batch/lot tracking for recall management
   - Price management with retail and insurance rates
   - Supplier information and purchase order history
   - Usage analytics and forecasting for procurement planning
   - Inventory adjustment with audit trail (reason recorded)
5. **Lab Technician Management**:
   - List of all lab technicians with roles and certifications
   - Workload distribution view (tests assigned vs. completed)
   - Performance metrics (tests completed, turnaround time, accuracy)
   - Schedule management with shift assignments
   - Certification tracking with expiry alerts
6. **Leave Approval Workflow**:
   - Calendar view showing all leave requests with color coding (pending, approved, rejected)
   - Department-wise filtering for focused view
   - Pending requests queue with quick approve/reject buttons and comment field
   - Coverage analysis showing gaps (days with insufficient coverage)
   - Leave balance tracking per doctor (accrued, used, remaining)
   - Automated conflict detection (multiple doctors from same department on leave)
7. **Appointment Overview**:
   - Daily/weekly/monthly appointment volumes with bar charts

- Utilization rates by doctor/department (percentage of slots filled)
- No-show rates and trends with patient history
- Cancellation analysis by reason and time before appointment
- Wait time metrics (average, 95th percentile) by doctor
- Resource allocation suggestions based on demand patterns

8. **Analytics and Reporting**:
   - Revenue reports with drill-down (by department, doctor, service type)
   - Patient demographics analysis (age, gender, location)
   - Popular services and treatments (frequency analysis)
   - Doctor performance comparisons (patients/hour, satisfaction, revenue)
   - Custom report builder with drag-and-drop fields and filters
   - Export capabilities (PDF, Excel, CSV) with formatting options
   - Scheduled report delivery via email (daily/weekly/monthly)
9. **System Configuration**:
   - Role and permission management (create roles, assign permissions)
   - Notification template editor (email, SMS, push templates with variables)
   - Integration settings (API keys, webhook URLs for third-party services)
   - Audit log viewer with search and export (user actions, timestamps, IPs)
   - Backup management (schedule backups, test restoration)
   - System health monitoring (CPU, memory, database performance)

Data Visualization:

- Charts for trends and comparisons using Chart.js or similar (line charts for trends, bar for comparisons)
- Heat maps for busy periods (appointment density by hour/day)
- Geographic maps for patient distribution (cluster view)
- Gantt charts for leave planning and resource allocation
- Real-time dashboard refresh (every 30 seconds for critical metrics) with WebSocket

3.6.5 Lab Technician Module

The laboratory technician module streamlines the complete workflow of test processing, from patient identification through result entry to report submission and notification. It is designed for efficiency and accuracy in high-volume laboratory environments, with validation at every step to ensure data quality and patient safety.

Component Architecture:

1. **Send Report Form**:
   - Multi-step form with validation at each step and progress indicator:
     (a) **Patient Selection**:
       - Search by patient ID, name, or contact with real-time suggestions
       - Auto-suggest based on recent patients (last 7 days) for speed
       - QR code scanner integration for mobile/tablet (camera-based)
       - Patient verification (DOB confirmation, name confirmation)
       - Display of patient demographics for visual confirmation
     (b) **Test Information**:
       - Test type dropdown categorized by department (hematology, chemistry, microbiology)
       - Dynamic form fields based on test type (different inputs for different tests)
       - Reference ranges display for context (age/gender-specific)
       - Test date/time picker (defaults to current time, but adjustable)
       - Ordering doctor selection with search (recent doctors first)
       - Additional notes field for special instructions
     (c) **Result Entry**:
       - Numeric fields with unit selection from predefined options
       - Real-time validation against reference ranges with visual feedback
       - Color indicators for abnormal values (yellow for abnormal, red for critical)
       - Text areas for qualitative results with spell check
       - Multiple entry for panels (multiple results per test with tab order)
       - Critical value confirmation dialog requiring acknowledgment
       - Comments and interpretations field for additional context
     (d) **File Upload**:
       - Drag-and-drop file upload area with visual feedback
       - Support for PDF, JPG, PNG, TIFF (max 25MB per file)
       - Multiple file upload capability with progress indicators

  - File preview before submission (thumbnail for images, first page for PDF)
  - Automatic file naming convention based on patient and test
  - Virus scanning status indicator (scanning, clean, infected)

(e) **Report Configuration**:
  - Priority selection radio buttons (normal, urgent, critical)
  - Priority impact explanation tooltips (notification differences)
  - Sharing preferences (doctor only, patient only, both) with radio buttons
  - Additional recipients option (email addresses for copy)
  - Confidentiality notice acknowledgment checkbox
  - Technician signature/ID field (auto-filled from login)

(f) **Review and Submit**:
  - Summary of all entered data in organized sections
  - Edit buttons for each section to go back and correct
  - Validation summary (all required fields completed)
  - Submit button with confirmation dialog
  - Save as draft option for partial completion

2. **Patient History Table**:
   - Searchable table of patients with recent tests (last 30 days)
   - Columns: Patient Name, ID, Recent Tests (count), Last Test Date, Actions
   - Click to view complete test history with trend graphs for repeated tests
   - Trend visualization for repeated tests (line charts for quantitative results)
   - Previous results for comparison (displayed alongside new results)
   - Flag for patients with pending reports (needs attention)
3. **Statistics Dashboard**:
   - **Today's Tests**: Total completed today with comparison to yesterday
   - **Pending Reports**: Count awaiting processing (by priority)
   - **Completed Today**: Successfully submitted reports with breakdown
   - **Urgent Cases**: High-priority pending tests requiring immediate attention
   - **Average Turnaround Time**: Performance metric (time from order to completion)
   - **Your Queue**: Personal workload (assigned tests)
   - **Department Statistics**: Team performance with averages
4. **Quality Control Panel**:

- Control results entry for quality assurance samples
- QC charts and trending (Levey-Jennings plots)
- Equipment status tracking (calibration due, maintenance)
- Reagent lot tracking with expiry alerts
- Proficiency testing records and results

5. **Recent Activity Feed**:
   - Chronological list of recent submissions (last 24 hours)
   - Status updates (submitted, reviewed by doctor, printed)
   - Quick reprint/re-send options for troubleshooting
   - Error notifications and resolutions (failed uploads, validation errors)

Workflow Optimization:

- Keyboard shortcuts for common actions (Ctrl+N new report, Ctrl+S save, Ctrl+F search)
- Default values for frequent tests (pre-filled based on last entry)
- Templates for common result patterns (e.g., "Normal" for routine results)
- Auto-save of drafts every 30 seconds to prevent data loss
- Batch processing for multiple samples from same patient (group entry)
- Integration with laboratory equipment for direct data import (LIS interface)
- Barcode scanning for sample tracking and error reduction

3.6.6 Appointment Booking Module

The appointment booking module provides patients with an intuitive interface for finding and scheduling appointments with doctors. It incorporates real-time availability, intelligent suggestions, and comprehensive booking management features to ensure a seamless experience.

Component Architecture:

1. **Doctor Search Interface**:
   - Search bar for doctor name, specialty, hospital with autocomplete
   - Advanced filters expandable panel:
     - Specialization (multi-select with department grouping)
     - Hospital/Location (with distance sorting if location enabled)

  - Available dates (calendar picker with availability indicators)
  - Gender preference (male, female, any)
  - Languages spoken (multi-select)
  - Insurance accepted (search by insurance provider)
  - Rating range (slider for minimum rating, e.g., 4+ stars)
  - Consultation fee range (slider with currency)
  - Available today/tomorrow/this week (quick filters)
- Map view for location-based search (shows doctors near user)
- Sort options (by rating, experience, fee low-high, next available)
- Search results display with clear card layout:
  - Doctor photo, name, specialization for quick identification
  - Hospital name and distance (if location available)
  - Rating stars and review count with breakdown
  - Consultation fee with insurance indicator
  - Next available slot (e.g., "Tomorrow 10:30 AM")
  - Book button with availability preview

2. **Doctor Profile View**:
   - Detailed information organized in tabs:
     - **About**: Complete qualifications, certifications, and bio
     - **Experience**: Years of experience, previous positions, special training
     - **Specializations**: Areas of expertise with descriptions
     - **Languages**: Languages spoken with fluency levels
     - **Fees**: Consultation fees (in-person/video) with payment options
     - **Location**: Complete address with map, parking information, photos of facility
     - **Reviews**: Patient reviews and ratings with date and verified badge
     - **Availability**: Calendar view with available slots
3. **Availability Calendar**:
   - Monthly/weekly/day view options with toggle
   - Color-coded availability:
     - Green: Available slots (multiple)
     - Yellow: Limited availability (1-2 slots)
     - Red: Fully booked
     - Gray: Doctor not working (off day, leave)
   - Click on date to see detailed time slots below calendar

- Quick navigation to next available date (one-click)
- Timezone awareness (converts to user's timezone)
- Buffer times between appointments shown as blocked
- Holiday and leave indicators with tooltips

4. **Time Slot Selection**:
   - Grid of available time slots for selected date (15/30/60-minute increments)
   - Slots shown with time and duration (e.g., "10:30 AM (30 min)")
   - Real-time availability with auto-refresh every 30 seconds
   - Slot locking during selection (5-minute hold while completing booking)
   - Duration indication for different appointment types (consultation, procedure)
   - Preferred slot highlighting based on user history
   - Waitlist option for fully booked slots (notify when available)
5. **Booking Form**:
   - Reason for visit (text area with common templates: "New consultation", "Follow-up", "Urgent concern")
   - Symptoms description with structured input (onset, duration, severity)
   - Previous visit reference (if follow-up, select from history)
   - Appointment type selector (in-person/video) with availability check
   - Insurance information selection (from saved profiles)
   - Special requests or notes for doctor
   - Emergency contact confirmation (verify or update)
6. **Confirmation Modal**:
   - Appointment summary with clear formatting:
     - Doctor name and photo for verification
     - Date and time with timezone
     - Location with map link or video meeting link
     - Fee breakdown (consultation, taxes, total)
     - Token number (if applicable) for physical visits
     - Cancellation policy reminder (time window, fees)
   - Calendar integration buttons (Google, Apple, Outlook) with one-click
   - Add to phone calendar option with .ics download
   - Set reminder preferences (when, how)

- Proceed to payment button (if required) with amount
- Confirm and book button (final step)

7. **Rescheduling Interface**:
   - Similar to booking flow but with original appointment context
   - Original appointment details displayed for reference
   - Reason for rescheduling required (dropdown + optional text)
   - Availability shown with current appointment time blocked
   - Notification preview (who will be notified)
   - Rescheduling fee indicator (if applicable based on policy)
8. **Cancellation Interface**:
   - Reason selection (dropdown: changed mind, found alternative, emergency, other)
   - Refund eligibility calculator based on cancellation policy
   - Confirmation with policy reminder and consequences
   - Feedback request option (optional survey)
   - Notification preview (who will be notified)

Business Logic:

- Slot availability calculated as: (doctor working hours - booked appointments - leave periods - buffer times)
- Concurrent booking prevention through database transactions with row-level locking
- Waitlist management with auto-booking when slots open (first-come, first-served)
- Intelligent slot suggestions based on patient history (preferred times)
- Machine learning for appointment duration prediction based on reason and patient history

3.6.7 Payment Integration Module

The payment integration module handles all financial transactions securely, integrating with multiple payment gateways while maintaining comprehensive internal records for reconciliation and audit purposes. It is designed to support multiple payment methods, currencies, and regional requirements.

Component Architecture:

1. **Payment Gateway Abstraction Layer**:

- Unified interface for multiple gateways (Stripe, Razorpay, PayPal)
- Gateway-specific adapters implementing common interface (create payment, refund, webhook)
- Automatic fallback to secondary gateway on primary failure (circuit breaker pattern)
- Webhook handling with signature verification for each gateway
- Idempotency keys to prevent duplicate processing (retry-safe)

2. **Payment Intent Creation**:
   - Creates payment intent with gateway via API
   - Returns client secret for front-end tokenization (PCI compliance)
   - Stores intent ID with payment record for reconciliation
   - Sets expiration time for payment (30 minutes typical)
   - Includes metadata (appointment ID, patient ID) for webhook processing
3. **Payment Method Selection UI**:
   - Card payment with PCI-compliant iframe (Stripe Elements)
   - Saved cards management (tokenized, last 4 digits display)
   - Digital wallets (Apple Pay, Google Pay) with device detection
   - Insurance billing information capture (policy number, group ID)
   - Cash payment recording (for admin use in clinics)
   - UPI/Bank transfer options (region-specific, QR code display)
4. **Payment Processing Flow**:
   - Amount display with clear breakdown:
     - Consultation fee (base amount)
     - Taxes (GST/VAT percentage and amount)
     - Discounts applied (promotional, insurance)
     - Total amount due
   - Loading states during processing with spinner and timeout indicator
   - Success/failure/pending screens with appropriate messaging
   - Retry logic for failed payments (3 attempts with exponential backoff)
   - Timeout handling (30 seconds, then show timeout message)
5. **Invoice Generation Engine**:
   - PDF generation using templates (jsPDF or server-side library)

- Includes comprehensive information:
  - Hospital logo and details (name, address, tax ID)
  - Patient name and ID
  - Appointment details (doctor, date, time)
  - Itemized charges with descriptions
  - Tax breakdown by rate
  - Payment reference and transaction ID
  - QR code for verification (scan to validate)
- Email delivery with attachment (PDF)
- Storage in cloud with access URL (signed URL with expiry)
- Invoice numbering sequence (unique, sequential per hospital)
- GST/Tax invoice compliance for regions requiring it

6. **Refund Processing Module**:
   - Refund eligibility check based on cancellation policy
   - Proration calculation for partial refunds (percentage or fixed)
   - Gateway refund API integration with appropriate parameters
   - Approval workflow for large refunds (¿threshold requires second admin)
   - Partial refund support (amount field)
   - Refund reason tracking (dropdown + text)
   - Credit note generation (separate document)
7. **Payment History and Reconciliation**:
   - Transaction listing with filters (date range, status, method)
   - Settlement tracking (pending, settled, failed)
   - Dispute management (view, respond, track status)
   - Reconciliation reports (transactions vs. gateway statements)
   - Export for accounting systems (CSV, Excel, QuickBooks format)
   - Audit log of all financial actions (who, what, when)
8. **Webhook Handler**:
   - Secure endpoint with signature verification (gateway-specific)
   - Event type processing (payment.succeeded, payment.failed, refund.completed)
   - Idempotent processing via event IDs (ignore duplicates)
   - Automatic retry on failure with exponential backoff

- Logging for debugging and audit (request/response)

Security Measures:

- PCI DSS compliance through tokenization (no storage of raw card details)
- Encryption of sensitive data at rest (AES-256 for stored financial data)
- HTTPS for all communications (TLS 1.3)
- Fraud detection rules (velocity checks, amount thresholds, geographic anomalies)
- 3D Secure support for additional authentication
- Rate limiting on payment endpoints (5 per minute per user)

3.6.8 Real-time Chat Module

The real-time chat module enables secure, instant communication between patients and doctors, supporting text messages, file sharing, and read receipts. Built on Socket.io, it provides a responsive messaging experience while maintaining message persistence for medical record keeping and legal compliance.

Component Architecture:

1. **WebSocket Server** (Socket.io):
   - Handles real-time bidirectional communication with low latency
   - Authentication middleware for connection establishment (JWT validation)
   - Room-based architecture for private conversations (one room per conversation)
   - Scalability through Redis adapter for multi-server deployments
   - Connection state management and reconnection handling (automatic reconnect)
   - Heartbeat mechanism for connection health monitoring (ping/pong)
2. **Message Persistence Layer**:
   - All messages stored in PostgreSQL messages table with indexes
   - Indexed for fast conversation retrieval (sender_id, receiver_id, created_at)
   - Encryption at rest for sensitive medical discussions
   - Retention policy compliance with healthcare regulations (7 years)
   - Archive mechanism for old conversations (move to cold storage)
3. **Chat List Interface**:
   - Displays all recent conversations for the user with previews
   - Each conversation item shows:

  - Other participant's name and photo (avatar)
  - Last message preview (truncated to 50 characters)
  - Timestamp of last message (relative, e.g., "5 min ago")
  - Unread message count badge (red circle with number)
  - Online/offline status indicator (green dot for online)
  - Typing indicator when applicable (animated dots)
- Search functionality to find specific conversations (by participant name)
- Pin important conversations to top (star icon)
- Archive old conversations (hide from main list)
- Delete conversation option (with confirmation and audit)

4. **Message Thread View**:
   - Chronological display of messages in a conversation with infinite scroll
   - Date separators for messages from different days (e.g., "Yesterday", "March 4")
   - Message bubbles with clear sender identification:
     - Sent messages: Right-aligned, colored background (blue)
     - Received messages: Left-aligned, light background (gray)
     - System messages: Centered, grey (e.g., "Patient joined the chat")
   - Read receipts indicators (single tick: sent, double tick: delivered, blue double tick: read)
   - Delivery status for offline messages (sent when user comes online)
   - Timestamp display on hover or for each message (actual time)
   - File attachment preview (images shown inline, documents as icons with filename)
   - Download button for attachments with preview option
5. **Message Input Area**:
   - Rich text input with emoji picker (Emoji Mart integration)
   - File attachment button with type/size validation (max 25MB)
   - Supported file types: Images (JPG, PNG, GIF), Documents (PDF, DOC, DOCX)
   - Image preview before sending (crop, rotate options)
   - Voice message recording (optional integration with Web Audio API)
   - Typing indicator broadcast (shows "typing..." to other participant)
   - Send on Enter (configurable, Ctrl+Enter for new line)

- Character counter for long messages (max 2000 characters)

6. **Push Notification Service**:
   - Real-time notifications for new messages when user is offline
   - Integration with Firebase Cloud Messaging (FCM) for mobile apps
   - Web Push API for desktop browsers (service workers)
   - Notification content customization (show/hide message preview based on settings)
   - Sound alerts with mute option per conversation
   - Do Not Disturb hours configuration (global and per user)
7. **File Sharing Service**:
   - Secure file upload to cloud storage (AWS S3/Azure Blob) with unique naming
   - Virus scanning before storage (ClamAV integration)
   - File type validation by content (not just extension)
   - Size limit enforcement (25MB per file)
   - Automatic image compression for large files (resize to 1080p)
   - Expiring URLs for secure access (5-minute validity)
   - File encryption at rest (AES-256)
8. **Conversation History**:
   - Infinite scroll with pagination (load 20 messages at a time)
   - Search within conversation (full-text search)
   - Export conversation as PDF (for medical records)
   - Print conversation option (print-friendly formatting)
   - Date-based navigation (jump to specific date)

WebSocket Events:

- `connection`: Client connects to WebSocket server
- `authenticate`: Client sends JWT for authentication
- `join_conversation`: Client joins a specific conversation room (based on conversation ID)
- `leave_conversation`: Client leaves conversation room
- `send_message`: Client sends a new message (content, attachment reference)

- `message_received`: Server acknowledges message receipt (confirmation)
- `new_message`: Server broadcasts new message to recipient (real-time)
- `typing_start`: Client indicates typing started
- `typing_stop`: Client indicates typing stopped
- `message_read`: Client marks message as read
- `read_receipt`: Server broadcasts read receipt to sender
- `error`: Server sends error information (with code)
- `disconnect`: Client disconnects from server (cleanup)

Security Features:

- End-to-end encryption for sensitive medical discussions (optional, using Web Crypto API)
- Authentication required for all WebSocket connections (JWT validation)
- Rate limiting to prevent spam (10 messages per minute per user)
- Message filtering for prohibited content (PHI, profanity)
- Audit logging of all communications (who, when, what)
- Automatic logout on session expiry (WebSocket disconnect)
- HIPAA compliance through encryption and access controls

3.6.9 Notification Module

The notification module ensures timely communication across all platform events, delivering messages through multiple channels based on user preferences and event urgency. It handles appointment reminders, lab report notifications, prescription alerts, and system announcements with reliability and personalization.

Component Architecture:

1. **Notification Types and Templates**:
   - **Appointment Notifications**:
     - Confirmation: Sent immediately after booking (with details)
     - Reminder: 24 hours before appointment (with preparation instructions)
     - Reminder: 2 hours before appointment (for same-day, with check-in link)
     - Rescheduling: Notifies all parties of change (with new details)

  - Cancellation: Notifies all affected parties (with reason if available)
  - Follow-up: After appointment completion (with feedback request)
- **Lab Report Notifications**:
  - Report Ready: Alert to patient and/or doctor based on sharing preferences
  - Critical Result: Immediate alert with escalation (SMS + phone call)
  - Report Reviewed: Doctor has reviewed results (patient notified)
  - Report Updated: When corrections are made (with version info)
- **Prescription Notifications**:
  - New Prescription: When doctor issues prescription (with medicine list)
  - Refill Available: When refill is due (automatic reminder)
  - Refill Request: Patient requests refill (doctor notified)
  - Refill Approved/Rejected: Status update to patient (with reason)
  - Expiring Soon: Medication about to expire (with refill prompt)
- **Medicine Reminders**:
  - Daily Medication: Scheduled dosage reminders (with medicine name)
  - Refill Reminder: Low stock alert (reorder suggestion)
  - Missed Dose: Follow-up if dose not marked taken (with snooze)
- **System Notifications**:
  - Account Creation: Welcome email with verification link
  - Password Reset: Security notifications with token
  - Profile Updates: Confirmation of changes
  - Security Alerts: Unusual activity detected (new device, location)

2. **Multi-Channel Delivery Engine**:
   - **In-App Notifications**:
     - Real-time display in notification center (dropdown)
     - Badge counters on navigation icons (unread count)
     - Toast/popup notifications for urgent messages (auto-dismiss)
     - Mark as read/unread functionality (individual or all)
     - Clear all option for bulk actions
     - Persistent storage of notification history (30 days)
   - **Email Notifications** (via SendGrid/NodeMailer):
     - HTML email templates with responsive design (mobile-friendly)
     - Plain text alternative for compatibility (email clients)
     - Personalization with user name and dynamic content
     - Tracking pixels for open rates (with privacy opt-out)

  - Unsubscribe links for non-transactional notifications
  - DKIM/SPF compliance for deliverability
- **SMS Notifications** (via Twilio/MessageBird):
  - Concise messages with essential information (160 chars optimized)
  - Short links to relevant pages (bit.ly integration)
  - Opt-out support (STOP keyword for compliance)
  - Delivery status tracking (delivered, failed)
  - Rate limiting to prevent spam (per number)
  - Cost optimization through message bundling
- **Push Notifications** (via Firebase/Web Push):
  - Mobile app push notifications (iOS, Android)
  - Web browser push notifications (Chrome, Firefox, Safari)
  - Action buttons in notifications (e.g., "Confirm", "View", "Snooze")
  - Silent notifications for data sync (background updates)
  - Priority levels for delivery (high for critical alerts)

3. **Template Management System**:
   - Centralized template storage in database (versioned)
   - Variable substitution using {{variable}} syntax (e.g., {{patient_name}})
   - Multi-language support (English, Spanish, Hindi, etc.)
   - Version control for templates (history, revert)
   - Preview functionality before sending (test with sample data)
   - A/B testing capability for marketing notifications
   - Template inheritance for consistent branding
4. **Notification Scheduler**:
   - Cron jobs for scheduled notifications (reminders)
   - Queue-based processing for reliability (Bull/Redis)
   - Retry logic for failed deliveries (exponential backoff, max 3 attempts)
   - Dead letter queue for persistent failures (manual review)
   - Timezone awareness for reminders (send at local time)
   - Throttling to prevent overwhelming users (max 5 per hour)
   - Batching of non-urgent notifications (daily digest)
5. **User Preferences Manager**:
   - Per-channel opt-in/opt-out (email, SMS, push, in-app)

- Quiet hours configuration (e.g., 10 PM - 8 AM no notifications)
- Frequency preferences (immediate, daily digest, weekly summary)
- Notification type granularity (appointment vs. marketing)
- Device-specific settings (mobile vs. desktop)
- Preference persistence and sync across devices

6. **Delivery Analytics**:
   - Delivery success/failure tracking by channel
   - Open rates for email (unique opens)
   - Click-through rates (links clicked)
   - Opt-out tracking (unsubscribes by channel)
   - Channel effectiveness analysis (which channel works best)
   - Cost per notification reporting (for budget optimization)

Queue Architecture:

- Bull/Redis queue for notification jobs with priorities
- Priority queues (critical ¿ transactional ¿ promotional)
- Delayed jobs for scheduled notifications (future send times)
- Failed job retry with exponential backoff (3 attempts)
- Job deduplication to prevent duplicate sends (same event within window)
- Rate limiting per user/channel (configurable)
- Monitoring dashboard for queue health (Bull Board)

3.7 Security Architecture

The BondHealth platform implements a comprehensive, defense-in-depth security architecture to protect sensitive healthcare data, ensure regulatory compliance (HIPAA, GDPR), and maintain system integrity. Security is integrated at every layer of the application, from network perimeter to database storage, with multiple overlapping controls ensuring that no single point of failure compromises patient data.

Security Principles:

- **Defense in Depth**: Multiple layers of security controls ensure that if one layer fails, others continue to provide protection. This includes network security, application security, data security, and physical security layers.

- **Least Privilege**: Users and services have only the minimum permissions necessary to perform their functions. No user has access to data they don't need, and service accounts are similarly restricted.
- **Secure by Default**: Default configurations are secure, requiring explicit actions to reduce security. Features are off unless needed, and secure options are preselected.
- **Fail Secure**: When failures occur, the system fails into a secure state rather than an insecure one. Errors default to denying access rather than granting it.
- **Complete Mediation**: Every access attempt is checked for authorization, not just the first. Each request is validated independently.
- **Separation of Duties**: Critical operations require multiple people or steps. For example, large refunds require two admin approvals.
- **Privacy by Design**: Privacy considerations are built into the system from the ground up, not added as an afterthought.

3.7.1 Authentication Security

JWT Implementation Details:

- Algorithm: HS256 (HMAC with SHA-256) for symmetric signing
- Secret key: 256-bit random value stored in environment variables, rotated quarterly
- Payload includes: user_id, username, role, session_id, issued_at (iat), expiration (exp)
- Token expiration: 7 days for access tokens (configurable per deployment)
- Refresh tokens: 30 days, stored in database with revocation capability
- Token versioning: Each user has token version counter, incremented on password change

Session Management:

- Redis store with key: `session:{session_id}` and TTL matching token
- Session data: user_id, ip_address, user_agent, created_at, last_activity
- Session timeout: 30 minutes of inactivity (sliding expiration, reset on activity)
- Maximum concurrent sessions: 5 per user (configurable, blocks new logins when exceeded)
- Session invalidation triggers: password change, admin force logout, account deactivation, suspicious activity

Password Policy:

- Minimum length: 8 characters
- Complexity: at least one uppercase, one lowercase, one number, one special character
- Password history: last 5 passwords prevented from reuse (hash comparison)
- Maximum age: 90 days (optional, configurable per organization)
- Account lockout: after 5 failed attempts (15-minute lockout, increments with each attempt)
- Password reset: email with expiring token (24-hour validity, single use)

3.7.2 Data Security

Encryption at Rest:

- Database: Transparent Data Encryption (TDE) at storage level (AES-256)
- Sensitive fields (PII, medical data): Application-level encryption with AES-256-GCM
- File storage: Server-side encryption with AWS KMS/Azure Key Vault (AES-256)
- Backups: Encrypted with separate keys (offsite storage)
- Key management: Hardware Security Module (HSM) for master keys, key rotation quarterly

Encryption in Transit:

- TLS 1.3 minimum for all external communications (no older protocols)
- Internal service communications: mTLS for service mesh (Istio/Linkerd)
- Database connections: TLS with certificate validation (mutual TLS)
- API endpoints: HSTS preload, perfect forward secrecy (ECDHE)

Data Classification:

- **Restricted** (PHI/PII): Medical records, personal information - encryption required, access logging, minimal retention (7 years)
- **Confidential**: Financial data, appointment details - encryption required, access controls, audit logging
- **Internal**: Operational data - standard protection, access controls
- **Public**: Hospital information, doctor profiles - no restrictions, cacheable

3.7.3 Application Security

Input Validation:

- Schema validation using Joi/express-validator (strict typing)
- Type checking and coercion (numbers, booleans, dates)
- Range validation for numeric fields (min/max)
- Pattern matching for emails (RFC-compliant regex), phone numbers (E.164 format)
- Length limits on all string fields (prevent DoS)
- Sanitization of HTML content (DOMPurify, remove scripts)
- SQL injection prevention via parameterized queries (prepared statements)

Output Encoding:

- Context-aware encoding (HTML entities, JavaScript strings, CSS, URLs)
- Content Security Policy (CSP) headers with strict directives (default-src 'self')
- X-Content-Type-Options: nosniff (prevent MIME sniffing)
- X-Frame-Options: DENY (prevent clickjacking)
- X-XSS-Protection: 1; mode=block (legacy browsers)

CSRF Protection:

- SameSite=Strict cookies for all session cookies (modern browsers)
- CSRF tokens for state-changing operations (double-submit pattern)
- Origin and Referer header validation (server-side check)
- Idempotent operations for GET requests (no side effects)

3.7.4 Infrastructure Security

Network Security:

- VPC with private subnets for databases (no public internet access)
- Security groups with least privilege access (IP whitelisting)
- Web Application Firewall (WAF) for DDoS protection (AWS WAF/Cloudflare)
- API Gateway for rate limiting and throttling (1000 requests per minute per IP)
- VPN access for administrative functions (AWS Client VPN)

- Network segmentation between tiers (web, app, db in separate subnets)

Server Hardening:

- Minimal base images with only necessary packages (Alpine Linux)
- Regular security patches and updates (weekly automated scans)
- Host-based intrusion detection (HIDS) with Wazuh/OSSEC
- File integrity monitoring (Tripwire/AIDE)
- Root login disabled, SSH key authentication only
- Principle of least privilege for service accounts (non-root users)

Container Security:

- Image scanning for vulnerabilities (Trivy/Clair) in CI/CD
- Read-only root filesystems (immutable infrastructure)
- Non-root user execution (containers run as user 1000)
- Resource limits to prevent DoS (CPU/memory limits)
- Secrets management (no secrets in images, use HashiCorp Vault)
- Runtime security monitoring (Falco for anomalous activity)

3.7.5 Compliance and Audit

HIPAA Compliance:

- Business Associate Agreements with all vendors (signed)
- Access controls and audit trails for all PHI (who accessed what, when)
- Encryption of PHI at rest and in transit (AES-256, TLS 1.3)
- Breach notification procedures (72-hour notification)
- Minimum necessary access principle (role-based)
- Automatic logout after inactivity (15 minutes)
- Emergency access procedures (break-glass accounts with audit)

GDPR Compliance:

- Consent management for data processing (explicit opt-in)
- Right to access and data portability (export user data)

- Right to erasure (right to be forgotten) with verification
- Data processing records (Article 30 documentation)
- Privacy by design in all features (DPIA for new features)
- Data Protection Impact Assessments (DPIA) for high-risk processing

Audit Logging:

- Log all authentication attempts (success/failure with IP, user agent)
- Log all access to PHI (who, what, when, why - patient ID, record type)
- Log all data modifications (before/after values for critical fields)
- Tamper-evident logging with cryptographic hashes (hash chains)
- Centralized log aggregation (ELK stack) with search and alerting
- 7-year log retention for compliance (cold storage after 90 days)
- Regular log review and anomaly detection (automated alerts)

Security Monitoring:

- SIEM integration for real-time alerting (Splunk/ELK)
- Anomaly detection for unusual access patterns (ML-based)
- Brute force attack detection (multiple failures from same IP)
- Unusual geographic access alerts (impossible travel)
- Data exfiltration monitoring (large data transfers)
- 24/7 security operations center (SOC) escalation for critical alerts

3.8 Database Connection Design (Neon PostgreSQL)

The database connection architecture is designed for optimal performance, reliability, and security when connecting the Node.js application layer to Neon PostgreSQL. Connection pooling, proper error handling, and secure configuration are critical components of this design, ensuring efficient resource utilization and consistent performance under varying load.

3.8.1 Connection Pooling Architecture

Connection pooling maintains a cache of database connections that can be reused across multiple client requests, eliminating the overhead of establishing a new connection for each database operation. This is particularly important for serverless and high-concurrency environments where connection establishment costs can significantly impact performance.

Pool Configuration:

- **Min Pool Size**: 5 connections (maintain at least 5 connections even when idle to handle sudden spikes)
- **Max Pool Size**: 20 connections (maximum connections in the pool, limits database load)
- **Connection Timeout**: 10 seconds (time to wait for a connection from pool before error)
- **Idle Timeout**: 30 seconds (close idle connections after this time to free resources)
- **Max Lifetime**: 30 minutes (recycle connections periodically to avoid stale connections)
- **Queue Limit**: 50 (maximum queued requests when pool is exhausted, prevents memory overflow)

Pool Benefits:

- Reduced latency (no connection setup overhead, saving 20-50ms per request)
- Better resource utilization (controlled number of connections, prevents database overload)
- Connection limit protection (prevents database from being overwhelmed)
- Automatic recovery (replaces failed connections transparently)
- Load smoothing (handles traffic spikes gracefully without connection storms)

3.8.2 Connection Implementation

The following code implements the connection pool with comprehensive error handling and monitoring:

```
// config/database.js - Database connection configuration
require('dotenv').config();
const { Pool } = require('@neondatabase/serverless');

// Create connection pool with optimal configuration
```

```
const pool = new Pool({
    connectionString: process.env.DATABASE_URL,
    ssl: {
        require: true,              // Enforce SSL connection
        rejectUnauthorized: true     // Verify server certificate (prevents MITM)
    },
    max: 20,                         // Maximum pool size
    idleTimeoutMillis: 30000,        // Close idle connections after 30s
    connectionTimeoutMillis: 10000,   // Return error after 10s if no connection
    maxUses: 7500,                    // Recycle connection after 7500 uses
});

// Enhanced query function with logging and error handling
const query = async (text, params) => {
    const start = Date.now();
    try {
        const res = await pool.query(text, params);
        const duration = Date.now() - start;

        // Log slow queries for optimization (threshold: 100ms)
        if (duration > 100) {
            console.warn('Slow query detected:', { text, duration, rows: res.rowCou
        }

        // Log all queries in development for debugging
        if (process.env.NODE_ENV === 'development') {
            console.log('Executed query:', { text, duration, rows: res.rowCount });
        }

        return res;
    } catch (error) {
        // Structured error logging (sanitized, no sensitive data)
        console.error('Database query error:', {
            message: error.message,
            code: error.code,
            detail: error.detail,
            query: text,
            params: params ? params.map(p => typeof p) : [] // Log types only, not
        });

        // Throw normalized error for consistent handling
        throw new DatabaseError(error.message, error.code);
```

```
    }
};

// Transaction support with automatic rollback on error
const transaction = async (callback) => {
    const client = await pool.connect();
    try {
        await client.query('BEGIN');
        const result = await callback(client);
        await client.query('COMMIT');
        return result;
    } catch (error) {
        await client.query('ROLLBACK');
        throw error;
    } finally {
        client.release();
    }
};

// Health check function for monitoring
const healthCheck = async () => {
    const start = Date.now();
    try {
        const res = await pool.query('SELECT 1');
        return {
            status: 'healthy',
            latency: Date.now() - start,
            poolSize: pool.totalCount,
            idle: pool.idleCount,
            waiting: pool.waitingCount
        };
    } catch (error) {
        return { status: 'unhealthy', error: error.message };
    }
};

// Graceful shutdown for application termination
const closePool = async () => {
    console.log('Closing database connection pool...');
    await pool.end();
    console.log('Database pool closed');
};
```

```
// Handle application termination signals
process.on('SIGINT', closePool);
process.on('SIGTERM', closePool);

module.exports = { pool, query, transaction, healthCheck, closePool };
```

3.8.3 Connection Security

SSL/TLS Configuration:

- SSL mode: `require` (enforces encryption, fails if not available)
- Certificate validation: Enabled (prevents MITM attacks, verifies server identity)
- Minimum TLS version: TLSv1.2 (disables older, insecure versions)
- Cipher suites: Strong ciphers only (AES-GCM, ChaCha20-Poly1305)
- Certificate pinning: Optional for additional security (store server certificate hash)

Credential Management:

- Connection string stored in environment variables (`DATABASE_URL`)
- Never committed to version control (.gitignore enforced)
- Rotated quarterly or after any security incident (automated)
- Separate credentials for read-only replicas (if used for reporting)
- IAM roles for cloud environments (AWS RDS IAM authentication, no static passwords)

3.8.4 Error Handling and Retry Logic

Connection Errors:

- Transient errors (timeouts, temporary failures): Automatic retry with exponential backoff (100ms, 500ms, 1s, 5s)
- Permanent errors (authentication failure, invalid database): Log and alert, no retry (requires human intervention)
- Connection exhaustion: Queue requests with timeout, return 503 Service Unavailable with retry-after header

Query Errors:

- Syntax errors: Return 400 Bad Request (client error, needs correction)

- Constraint violations (unique, foreign key): Map to appropriate HTTP status codes (409 Conflict)
- Deadlocks: Automatic retry (up to 3 times) with random delay
- Serialization failures: Retry transaction with exponential backoff

3.8.5 Monitoring and Alerting

Metrics Collected:

- Pool size (current, active, idle, waiting) - for capacity planning
- Query latency (average, p95, p99) - for performance monitoring
- Error rates by error type (syntax, constraint, connection) - for reliability
- Connection acquisition wait time - for pool sizing
- Transaction throughput (per second/minute) - for load analysis
- Connection age and reuse count - for connection health

Alert Thresholds:

- Pool exhaustion (waiting queries ¿ 10) → Alert (scale needed)
- High latency (p95 ¿ 500ms for 5 minutes) → Alert (query optimization needed)
- Error rate ¿ 5
- Connection acquisition timeout ¿ 1s → Warning (pool saturation)
- Database disconnection → Critical alert (immediate action)

3.9 Third-party Integrations

The BondHealth platform integrates with multiple external services to extend functionality, enhance user experience, and leverage specialized capabilities while maintaining focus on core healthcare features. Each integration is carefully selected for reliability, security, and compliance with healthcare regulations, with appropriate fallbacks and error handling.

3.9.1 Integration Architecture Principles

- **Abstraction**: Integration logic encapsulated behind service interfaces, allowing easy replacement of providers
- **Resilience**: Circuit breakers, retries, and fallbacks for all external calls (Hystrix pattern)

- **Security**: API keys stored securely in environment variables or vault, never in code
- **Monitoring**: All external calls tracked for performance, errors, and availability
- **Compliance**: Business Associate Agreements (BAAs) for healthcare data with all vendors
- **Cost Optimization**: Request caching and batching where appropriate to minimize API calls
- **Versioning**: API version pinning to prevent breaking changes

3.9.2 Payment Gateway Integration Details

Stripe Integration:

- **API Version**: 2023-10-16 (pinned to avoid breaking changes)
- **Authentication**: Secret key stored in environment variables (rotated quarterly)
- **Payment Methods**: Cards, Apple Pay, Google Pay, bank transfers (ACH), Buy Now Pay Later
- **Webhooks**: Payment intent succeeded/failed, refund updated, dispute created, payout completed
- **Idempotency**: Idempotency keys prevent duplicate charges (retry-safe)
- **Receipts**: Automatic email receipts from Stripe (optional, can override)
- **Connect**: For marketplace scenarios (future expansion to multi-hospital)

Razorpay Integration (India-specific):

- **API Version**: 1.0
- **Payment Methods**: Cards, UPI, NetBanking, Wallets, EMI, BNPL
- **Webhooks**: Payment authorized/captured/refunded, settlement processed
- **Invoices**: Generate GST-compliant invoices with tax breakdown
- **Settlement**: Automatic settlement to bank accounts (daily/weekly)

3.9.3 File Storage Integration Details

AWS S3 Configuration:

- **Bucket Structure**: `/bucket-name/tenant-id/document-type/year/month/uuid-filename` for organization
- **Encryption**: Server-side encryption with AWS KMS (SSE-KMS) using customer-managed keys
- **Access Control**: Presigned URLs for upload/download (5-minute expiry, single-use)
- **Lifecycle Rules**: Move to Glacier after 90 days (cost optimization), delete after 7 years (compliance)
- **Versioning**: Enabled for audit trail and recovery (30-day version retention)
- **Cross-region replication**: Optional for disaster recovery (secondary region)

Azure Blob Storage Configuration:

- **Container**: Private container with SAS tokens for access (time-limited)
- **Access Tier**: Hot for active documents (0-90 days), Cool for archives (90-365 days)
- **Encryption**: Azure Storage Service Encryption with customer-managed keys
- **Soft Delete**: 30-day retention for deleted files (recovery option)

3.9.4 Notification Service Integration Details

Twilio SMS Integration:

- **Phone Numbers**: Toll-free numbers for US/CAN, local numbers for other regions
- **Messaging Service**: Pool of numbers for high availability and load balancing
- **Templates**: Pre-approved templates for compliance (A2P 10DLC)
- **Status Callbacks**: Webhooks for delivery status (delivered, failed, undelivered)
- **Opt-out Management**: Automatic handling of STOP/HELP keywords

3.10 Performance Optimization

The BondHealth platform implements multiple optimization strategies to ensure responsive user experiences even under high load, with sub-second response times for critical operations. These optimizations span database, application, and infrastructure layers, ensuring scalability as user base grows.

Database Optimization:

- Database indexing on frequently queried columns such as email addresses, user roles, appointment dates, and foreign key relationships significantly reduces query execution times (10-100x improvement)
- Connection pooling minimizes database connection overhead and manages concurrent access efficiently (reduces connection establishment from 50ms to near zero)
- Query optimization through EXPLAIN analysis and index tuning (regular review)
- Read replicas for reporting queries to offload primary database (separate read-only connection)
- Partitioning for large tables (appointments by date, logs by month) to improve query performance

Caching Strategy:

- Redis caching for frequently accessed data such as doctor lists, specializations, and hospital information (5-minute TTL)
- Session data stored in Redis for fast access (sub-millisecond)
- Response caching for public endpoints (doctor directory, hospital info) with CDN
- Database query caching for expensive but static queries (reference data)
- Object caching for user profiles after authentication (reduce database hits)

API Optimization:

- Pagination for all list endpoints including appointments, patients, and reports, ensuring response sizes remain manageable (default 20 items per page)
- Field selection (sparse fields) to allow clients to request only needed data
- Compression (gzip/brotli) for API responses reduces bandwidth by 70-80
- HTTP/2 multiplexing for parallel requests
- Batch endpoints for mobile clients to reduce round trips

Frontend Optimization:

- Lazy loading for images and file attachments improves initial page load times (images load as user scrolls)
- Code splitting for JavaScript bundles (load only what's needed per page)
- Asset minification and bundling (Webpack/Rollup)
- CDN for static assets (images, CSS, JS) with edge caching (Cloudflare)

- Service workers for offline capability and caching (PWA)

Infrastructure Scaling:

- Horizontal scaling through stateless application design, allowing multiple Node.js instances to handle increased load (auto-scaling based on CPU/memory)
- Load balancing with NGINX/HAProxy across instances (round-robin with health checks)
- Auto-scaling groups based on metrics (CPU ¿ 70%, request queue length)
- Database read replicas can distribute query load (up to 5 replicas)
- CDN for static assets reduces origin load by 90%

Monitoring and Alerting:

- Real-time performance monitoring with DataDog/New Relic (dashboards for all metrics)
- Alerting on performance degradation (p95 latency ¿ 500ms)
- Log aggregation for slow query analysis (ELK stack with Kibana dashboards)
- Synthetic monitoring for critical user journeys (booking, login) from multiple locations
- Business metrics tracking (appointments per minute, active users) for capacity planning

Table 3.1: Users Schema - Core table storing authentication credentials and base user information for all system users. This table serves as the foundation for role-based access control and contains the minimal data required for authentication and session management. Each user has a unique identifier and can be associated with a hospital if they are staff (doctors, admins, lab technicians).

Property Name	**Description**	**Data Type**	**Constraints**
user_id	Unique identifier for each user, generated as UUID v4 to ensure global uniqueness across distributed systems	UUID	PRIMARY KEY, DEFAULT uuid_generate_v4()
username	Unique username chosen by user for login, must be between 3-50 characters, alphanumeric with underscores allowed	VARCHAR(100)	NOT NULL, UNIQUE
email	User's email address used for login, notifications, and password recovery. Verified during registration	VARCHAR(255)	NOT NULL, UNIQUE
password_hash	Bcrypt hash of user's password with 10 salt rounds, never stores plaintext passwords	VARCHAR(255)	NOT NULL
role	User's role in the system determining access permissions. Values: 'patient', 'doctor', 'admin', 'lab'	VARCHAR(50)	NOT NULL, CHECK
hospital_id	Reference to the hospital this user belongs to (NULL for patients who may not be associated with a specific hospital)	UUID	FOREIGN KEY references hospitals
is_active	Flag indicating whether the account is active (true) or deactivated/suspended (false)	BOOLEAN	DEFAULT true
last_login	Timestamp of the user's most recent successful login, used for security monitoring and inactivity checks	TIMESTAMP	NULL
created_at	Timestamp when the user account was created, automatically set by database	TIMESTAMP	DEFAULT CURRENT_TIMESTAMP
updated_at	Timestamp when the user record was last modified, updated automatically via trigger	TIMESTAMP	DEFAULT CURRENT_TIMESTAMP

Table 3.2: Hospitals Schema - Stores comprehensive information about healthcare facilities registered in the BondHealth platform. Each hospital can have multiple doctors and lab technicians associated with it. The table includes both contact information and classification details for filtering and reporting.

Property Name	**Description**	**Data Type**	**Constraints**
hospital_id	Unique identifier for each hospital, UUID format for distributed systems	UUID	PRIMARY KEY, DEFAULT uuid_generate_v4()
hospital_uuid	Human-readable unique identifier for display purposes, often used in URLs and reports	VARCHAR(50)	UNIQUE
name	Official name of the hospital or clinic as registered with healthcare authorities	VARCHAR(255)	NOT NULL
type	Classification of healthcare facility: Govt (government hospital), Private (private hospital), Clinic (smaller clinic)	VARCHAR(50)	CHECK
address	Complete physical address including street, building, landmark, and postal code	TEXT	NULL
city	City where the hospital is located, used for geographic searching and filtering	VARCHAR(100)	NULL
phone	Primary contact phone number for the hospital reception or administration	VARCHAR(20)	NULL
email	Official email address for hospital communications	VARCHAR(255)	NULL
created_at	Timestamp when the hospital record was added to the system	TIMESTAMP	DEFAULT CURRENT_TIMESTAMP

Table 3.3: Patients Schema - Extended profile information for users with role='patient'. Contains medical information, emergency contacts, and healthcare-specific data fields. The use of array data types (TEXT[]) allows efficient storage of multiple medical conditions and allergies without creating separate junction tables, simplifying queries and improving performance.

Property Name	**Description**	**Data Type**	**Constraints**
patient_id	Unique identifier for patient record, separate from user_id to allow multiple patient profiles per user (e.g., family accounts for parents managing children)	UUID	PRIMARY KEY, DEFAULT uuid_generate_v4()
user_id	Reference to the associated user account in users table, enables one-to-one relationship between users and patients	UUID	UNIQUE, FOREIGN KEY references users ON DELETE CASCADE
patient_uuid	Display identifier for patient, often used on reports and in communications	VARCHAR(50)	UNIQUE
full_name	Patient's complete legal name as per identification documents	VARCHAR(255)	NOT NULL
date_of_birth	Patient's date of birth for age calculation and medical context	DATE	NULL
gender	Patient's gender identity for medical records	VARCHAR(20)	NULL
blood_type	Blood group classification (A+, A-, B+, B-, AB+, AB-, O+, O-) for emergency reference	VARCHAR(5)	NULL
phone	Primary contact number for the patient	VARCHAR(20)	NULL
email	Patient's email address for communications	VARCHAR(255)	NULL
address	Residential address of the patient	TEXT	NULL
emergency_contact_name	Name of person to contact in case of emergency	VARCHAR(255)	NULL
emergency_contact_phone	Phone number of emergency contact person	VARCHAR(20)	NULL
medical_conditions	Array of diagnosed medical conditions, stored as text array for efficient querying and filtering	TEXT[]	NULL
allergies	Array of known allergies and adverse reactions, stored as text array	TEXT[]	NULL
last_visit	Date of patient's most recent visit to any doctor in the net-	DATE	NULL

Table 3.4: Doctors Schema - Comprehensive profile information for healthcare providers. Includes professional details, availability patterns, and performance metrics. The `available_days` array stores days of the week when the doctor practices, enabling flexible scheduling patterns. The rating is calculated from patient feedback.

Property Name	**Description**	**Data Type**	**Constraints**
doctor_id	Unique identifier for doctor record	UUID	PRIMARY KEY, DEFAULT uuid_generate_v4()
user_id	Reference to associated user account, enabling login capabilities and linking to users table	UUID	UNIQUE, FOREIGN KEY references users ON DELETE CASCADE
hospital_id	Reference to hospital where doctor primarily practices	UUID	FOREIGN KEY references hospitals
doctor_uuid	Display identifier for doctor, used in URLs and reports	VARCHAR(50)	UNIQUE
full_name	Doctor's full name as per medical registration	VARCHAR(255)	NOT NULL
specialization	Primary medical specialty (e.g., Cardiology, Pediatrics, Orthopedics)	VARCHAR(100)	NULL
designation	Job title or position (e.g., Senior Consultant, Head of Department, Resident)	VARCHAR(100)	NULL
qualification	Educational qualifications and certifications (e.g., MBBS, MD, DM, Fellowship)	VARCHAR(255)	NULL
experience	Years of professional experience, stored as text to allow ranges (e.g., "10+ years", "5-10 years")	VARCHAR(50)	NULL
consultation_fee	Standard fee for a consultation, stored as text to accommodate currency symbols and different fee structures	VARCHAR(50)	NULL
email	Professional email address for communications	VARCHAR(255)	NULL
phone	Contact number for the doctor's office or personal (if provided)	VARCHAR(20)	NULL
address	Clinic or hospital address where doctor sees patients	TEXT	NULL
photo_url	URL to doctor's profile photograph stored in cloud storage	TEXT	NULL
available_days	Array of days when doctor is available (e.g.,	TEXT[]	NULL

Table 3.5: Appointments Schema - Core transactional table recording all patient-doctor appointments. Tracks the complete lifecycle from booking through completion or cancellation. Includes status tracking, timing information, and audit fields. Each appointment is uniquely identified and linked to patient, doctor, and hospital.

Property Name	**Description**	**Data Type**	**Constraints**
appointment_id	Unique identifier for each appointment	UUID	PRIMARY KEY, DEFAULT uuid_generate_v4()
appointment_uuid	Human-readable reference number for appointments, used in communications and patient portals	VARCHAR(50)	UNIQUE
patient_id	Reference to the patient who booked the appointment	UUID	FOREIGN KEY references patients ON DELETE CASCADE
doctor_id	Reference to the doctor who will provide the consultation	UUID	FOREIGN KEY references doctors ON DELETE CASCADE
hospital_id	Reference to the hospital where appointment will take place	UUID	FOREIGN KEY references hospitals
appointment_date	Date of the scheduled appointment	DATE	NOT NULL
appointment_time	Time slot for the appointment (e.g., “10:30 AM”, “14:00”)	VARCHAR(20)	NOT NULL
reason	Patient’s reason for visit or chief complaint, captured during booking	TEXT	NULL
status	Current status: ’pending’, ’confirmed’, ’completed’, ’cancelled’, ’rescheduled’, ’no-show’ for lifecycle tracking	VARCHAR(50)	DEFAULT ’pending’
type	Appointment type: ’in-person’, ’video’, ’phone’ for distinguishing consultation modes	VARCHAR(20)	DEFAULT ’in-person’
token_number	Queue token or sequence number for physical appointments	VARCHAR(20)	NULL
location	Specific room or location within hospital (e.g., “Room 105, 2nd Floor”)	VARCHAR(255)	NULL
notes	Internal notes about the appointment (not visible to patient), used by staff	TEXT	NULL

Table 3.6: Lab Reports Schema - Stores all laboratory test results and related information. Supports file attachments, priority levels, and sharing preferences. Enables complete tracking of the lab workflow from test order to result delivery, with appropriate metadata for clinical context.

Property Name	**Description**	**Data Type**	**Constraints**
report_id	Unique identifier for each lab report	UUID	PRIMARY KEY, DEFAULT uuid_generate_v4()
report_uuid	Display reference number for reports, used in patient portals and communications	VARCHAR(50)	UNIQUE
patient_id	Reference to the patient who is the subject of the test	UUID	FOREIGN KEY references patients ON DELETE CASCADE
doctor_id	Reference to the doctor who ordered the test	UUID	FOREIGN KEY references doctors
lab_tech_id	Reference to the lab technician who processed the test and entered results	UUID	FOREIGN KEY references lab_technicians
test_type	Type of laboratory test performed (e.g., "Complete Blood Count", "Lipid Profile", "Blood Glucose")	VARCHAR(100)	NOT NULL
test_date	Date when the test was performed (sample collection date)	DATE	NULL
results	Detailed test results, may include structured data or free text depending on test type	TEXT	NULL
findings	Doctor's interpretation and clinical findings after reviewing results	TEXT	NULL
file_url	URL to uploaded report file (PDF, image) in cloud storage	TEXT	NULL
status	Report status: 'pending', 'completed', 'reviewed', 'archived' for workflow tracking	VARCHAR(50)	DEFAULT 'pending'
priority	Urgency level: 'normal', 'urgent', 'critical' affecting notification behavior and display	VARCHAR(20)	DEFAULT 'normal'
shared_with	Access control: 'doctor', 'patient', 'both' determining who can view the report	VARCHAR(20)	DEFAULT 'doctor'
created_at	Timestamp when report was created (entry time)	TIMESTAMP	DEFAULT CURRENT_TIMESTAMP

Table 3.7: Prescriptions Schema - Manages medication prescriptions issued by doctors. Supports active prescription tracking, refill management, and medication history. Each prescription record represents a single medication with dosage instructions, allowing for multiple medications per consultation.

Property Name	**Description**	**Data Type**	**Constraints**
prescription_id	Unique identifier for each prescription item	UUID	PRIMARY KEY, DEFAULT uuid_generate_v4()
prescription_uuid	Reference number for the prescription, groups related medications from the same consultation	VARCHAR(50)	UNIQUE
patient_id	Reference to the patient receiving the medication	UUID	FOREIGN KEY references patients ON DELETE CASCADE
doctor_id	Reference to the prescribing doctor	UUID	FOREIGN KEY references doctors
medicine_name	Name of the prescribed medication (generic or brand name)	VARCHAR(255)	NOT NULL
dosage	Dosage amount and form (e.g., “500mg”, “1 tablet”, “10ml”, “2 puffs”)	VARCHAR(100)	NULL
frequency	Administration schedule (e.g., “Twice daily”, “Every 8 hours”, “Once daily at bedtime”)	VARCHAR(255)	NULL
valid_until	Date until which the prescription remains valid for refills	DATE	NULL
instructions	Additional instructions for the patient (e.g., “Take with food”, “Avoid alcohol”)	TEXT	NULL
status	Prescription status: ’active’, ’completed’, ’expired’, ’cancelled’ for lifecycle tracking	VARCHAR(50)	DEFAULT ’active’
created_at	Timestamp when prescription was written	TIMESTAMP	DEFAULT CURRENT_TIMESTAMP

Table 3.8: Doctor Leave Schema - Tracks leave applications and approvals for doctors. Ensures appointment availability reflects leave periods and enables coverage planning. Supports date ranges and status tracking for approval workflow.

Property Name	**Description**	**Data Type**	**Constraints**
leave_id	Unique identifier for each leave application	UUID	PRIMARY KEY, DEFAULT uuid_generate_v4()
doctor_id	Reference to the doctor applying for leave	UUID	FOREIGN KEY references doctors ON DELETE CASCADE
from_date	Start date of leave period (inclusive)	DATE	NOT NULL
to_date	End date of leave period (inclusive)	DATE	NOT NULL
reason	Reason for leave (e.g., "Vacation", "Sick leave", "Conference", "Personal")	TEXT	NULL
status	Leave status: 'Pending', 'Approved', 'Rejected', 'Completed', 'Cancelled' for workflow	VARCHAR(50)	DEFAULT 'Approved'
created_at	Timestamp when leave was applied	TIMESTAMP	DEFAULT CURRENT_TIMESTAMP

Table 3.9: Medicines Inventory Schema - Manages hospital pharmacy inventory, tracking stock levels, pricing, and expiry dates. Enables automated reorder alerts and expiry notifications to ensure medication availability and patient safety.

Property Name	**Description**	**Data Type**	**Constraints**
medicine_id	Unique identifier for each medicine item in inventory	UUID	PRIMARY KEY, DEFAULT uuid_generate_v4()
hospital_id	Reference to the hospital that maintains this inventory	UUID	FOREIGN KEY references hospitals
name	Name of the medicine (brand name or generic) with strength	VARCHAR(255)	NOT NULL
quantity	Current stock quantity available (number of units)	INTEGER	DEFAULT 0
price	Price per unit, stored as text to accommodate currency formatting and different pricing models	VARCHAR(50)	NULL
expiry_date	Date when the medicine batch expires, used for alerts and stock rotation	DATE	NULL
created_at	Timestamp when medicine record was added to inventory	TIMESTAMP	DEFAULT CURRENT_TIMESTAMP

Table 3.10: Payments Schema - Records all financial transactions processed through the platform. Links to appointments for context, tracks payment status, and stores gateway transaction references for reconciliation. Supports multiple payment methods and currencies.

Property Name	**Description**	**Data Type**	**Constraints**
payment_id	Unique identifier for each payment transaction	UUID	PRIMARY KEY, DEFAULT uuid_generate_v4()
payment_uuid	Reference number for payments, used on receipts and in communications	VARCHAR(50)	UNIQUE
appointment_id	Reference to the appointment being paid for (if applicable)	UUID	FOREIGN KEY references appointments
patient_id	Reference to the patient making the payment	UUID	FOREIGN KEY references patients
amount	Monetary amount of the transaction with two decimal precision	DECIMAL(10,2)	NOT NULL
currency	Three-letter currency code (e.g., 'USD', 'EUR', 'INR', 'GBP')	VARCHAR(10)	DEFAULT 'USD'
status	Payment status: 'pending', 'completed', 'failed', 'refunded', 'partially_refunded' for tracking	VARCHAR(50)	DEFAULT 'pending'
payment_method	Method used: 'card', 'cash', 'insurance', 'wallet', 'bank_transfer' for reconciliation	VARCHAR(50)	NULL
transaction_id	External transaction ID from payment gateway for reconciliation and support	VARCHAR(255)	NULL
invoice_url	URL to generated invoice PDF stored in cloud storage	TEXT	NULL
created_at	Timestamp when payment was initiated	TIMESTAMP	DEFAULT CURRENT_TIMESTAMP

Table 3.11: Messages Schema (Real-time Chat) - Stores all chat communications between patients and doctors. Supports text messages and file attachments, with read receipts for delivery tracking. Used for both real-time and asynchronous communication, maintaining complete conversation history for medical-legal purposes.

Property Name	**Description**	**Data Type**	**Constraints**
message_id	Unique identifier for each message	UUID	PRIMARY KEY, DEFAULT uuid_generate_v4()
sender_id	Reference to the user who sent the message	UUID	FOREIGN KEY references users
receiver_id	Reference to the user who should receive the message	UUID	FOREIGN KEY references users
content	Text content of the message (can be NULL if only attachment)	TEXT	NULL
attachment_url	URL to attached file (images, documents) if any	TEXT	NULL
is_read	Flag indicating whether the message has been read by the receiver	BOOLEAN	DEFAULT false
created_at	Timestamp when message was sent	TIMESTAMP	DEFAULT CURRENT_TIMESTAMP

Table 3.12: Authentication Endpoints - Public endpoints for user registration, login, and session management. These endpoints handle identity verification, token issuance, and session lifecycle. All authentication endpoints use HTTPS exclusively to prevent credential interception.

Method	**Endpoint**	**Description**	**Access**
POST	/api/auth/register	Register new user account with email verification. Accepts user details, validates input, creates user record, and sends verification email. Returns success with user ID and prompts for email verification.	Public
POST	/api/auth/login	Authenticate user credentials. Validates username/email and password, generates JWT token, sets HTTP-only cookie, records last login, and returns user profile with role-specific redirect URL. Implements rate limiting to prevent brute force.	Public
POST	/api/auth/logout	Terminate user session. Clears authentication cookie, removes session from active sessions store, and logs logout event for audit.	Authenticated
GET	/api/auth/me	Retrieve currently authenticated user's profile information. Validates token, fetches fresh user data from database, and returns complete profile including role-specific details. Used for session validation and profile display.	Authenticated
POST	/api/auth/refresh	Refresh expired JWT token. Validates refresh token, issues new access token, and updates cookie. Enables long-lived sessions without requiring re-login.	Authenticated
POST	/api/auth/forgot	Initiate password reset	Public

Table 3.13: Patient Endpoints - Comprehensive set of endpoints for patient-facing functionality. All endpoints require patient role authentication and provide access to patient-specific data. Responses are filtered to include only information relevant to the authenticated patient.

Method	**Endpoint**	**Description**	**Access**
GET	/api/patient	Retrieve complete patient profile including personal information, medical conditions, allergies, emergency contacts, and notification preferences. Joins data from users and patients tables for comprehensive response.	Patient
PUT	/api/patient	Update patient profile information. Validates input, updates allowed fields, and returns updated profile. Supports partial updates via JSON merge patch.	Patient
GET	/api/patient/medical-history	Retrieve complete medical history including past appointments, diagnoses, procedures, and clinical notes in chronological order. Supports date range filtering.	Patient
GET	/api/appointments	Get paginated list of patient's appointments with filtering by status (upcoming/past/completed), date range, and doctor. Returns appointment details including doctor information and location.	Patient
GET	/api/appointments/:id	Get detailed information for a specific appointment including full doctor profile, location details, payment status, and any consultation notes (if completed).	Patient
POST	/api/appointments	Book new appointment. Accepts doctor_id, date, time, reason, type. Validates availability, creates ap-	Patient

Table 3.14: Doctor Endpoints - Endpoints for doctor-specific functionality. All endpoints require doctor role authentication and provide access to patient data and clinical tools. Responses include only patients assigned to or seen by the authenticated doctor.

Method	Endpoint	Description	Access
GET	/api/doctor	Retrieve doctor's complete profile including professional information, schedule, consultation fees, performance metrics, and practice settings.	Doctor
PUT	/api/doctor	Update doctor profile. Allows modification of consultation fees, availability schedule, qualifications, contact information, and practice settings. Changes may require admin approval.	Doctor
GET	/api/appointments/today	Get today's complete appointment schedule ordered by time. Includes patient information, appointment status, and quick action flags. Updates in real-time as appointments change.	Doctor
GET	/api/appointments/upcoming	Get future appointments beyond today. Supports pagination, filtering by date range, and sorting. Returns comprehensive appointment details with patient summaries.	Doctor
GET	/api/appointments/:id	Get detailed appointment information including full patient history, previous consultations, and any pre-visit questionnaires completed.	Doctor
PUT	/api/appointments/:id/start	Mark appointment as started when consultation begins. Updates status to 'in-progress', records start time, and triggers any time-tracking logic.	Doctor
PUT	/api/appointments/:id/complete	Mark appointment as completed after consul-	Doctor

Table 3.15: Admin Endpoints - Administrative endpoints for hospital management. All endpoints require admin role authentication and provide comprehensive control over hospital operations, user management, and system configuration.

Method	**Endpoint**	**Description**	**Access**
GET	/api/hospital/data	Get comprehensive hospital data including statistics, doctor counts, appointment volumes, inventory status, and financial summaries. Returns dashboard data with visual-ready metrics.	Admin
PUT	/api/hospital/profile	Update hospital profile information including address, contact details, operating hours, branding, and configuration settings. Changes are audited.	Admin
POST	/api/hospital/add/doctor	Register new doctor in the system. Accepts complete doctor profile, creates user account with doctor role, assigns to departments, and sends welcome email with credentials.	Admin
PUT	/api/hospital/doctors/id	Update doctor information including profile, fees, schedule, department assignment, and employment status. Maintains change history.	Admin
DELETE	/api/hospital/doctors/id	Deactivate or remove doctor from system. Handles reassignment of future appointments to other doctors if needed and archives records appropriately.	Admin
GET	/api/hospital/doctors	Get paginated list of all doctors with filtering by department, specialization, status, and search. Returns comprehensive profiles with performance metrics.	Admin
POST	/api/hospital/add/medicine	Add new medicine to inventory. Accepts	Admin

Table 3.16: Lab Technician Endpoints - Endpoints for laboratory workflow management. All endpoints require lab role authentication and provide tools for test processing, result entry, and report management.

Method	Endpoint	Description	Access
GET	/api/lab/dashboard	Get lab technician dashboard data including today's test counts, pending items by priority, completed tests, urgent cases requiring immediate attention, and recent activity.	Lab
POST	/api/lab-reports	Create new lab report. Accepts patient_id, doctor_id, test_type, results, priority, sharing preferences, and file uploads. Validates required fields, performs range checks, and stores report with appropriate metadata.	Lab
GET	/api/lab-reports/pending	Get list of pending reports requiring completion or review. Supports filtering by priority (normal/urgent/critical) and date. Returns reports with patient and doctor information.	Lab
GET	/api/lab-reports/:id	Get specific lab report details including all fields, file references, and processing history. Used for review and editing.	Lab
PUT	/api/lab-reports/:id	Update existing lab report (for corrections or additions). Maintains version history and audit trail of changes with before/after values.	Lab
DELETE	/api/lab-reports/:id	Delete draft or incorrect report (with appropriate permissions). Only allowed within time window and requires reason. Maintains audit log of deletion.	Lab

Table 3.17: Payment Endpoints - Endpoints for payment processing and financial transactions. Access varies by role, with patients able to view their own payments and admins having full access for reconciliation and management.

Method	Endpoint	Description	Access
POST	/api/payments/create-intent	Create payment intent for appointment. Returns client secret for front-end tokenization, enabling secure card data capture without exposing sensitive details to server. Used for card payments.	Patient
POST	/api/payments/confirm	Confirm payment after gateway processing. Updates payment status from 'pending' to 'completed' or 'failed' based on gateway response, and updates associated appointment status accordingly.	Patient
GET	/api/payments/:id	Get detailed payment information including status, amount, method, transaction reference, and timestamps. Used for receipt viewing and reconciliation.	Patient/Admin
GET	/api/payments/history	Get paginated payment history for patient (own payments) or all payments (admin). Supports filtering by date range, status, payment method. Returns comprehensive transaction details.	Patient/Admin
POST	/api/payments/refund	Process refund for cancelled appointment or adjustment. Requires admin approval for amounts above configurable threshold. Updates payment status and generates credit note.	Admin
POST	/api/payments/webhook	Webhook endpoint for payment gateway callbacks. Securely pro-	Public (secured by signature)

Table 3.18: Chat Endpoints - Endpoints for real-time messaging between patients and doctors. Supports both REST for history retrieval and WebSocket for real-time communication. All messages are encrypted and stored for medical-legal purposes.

Method	**Endpoint**	**Description**	**Access**
GET	/api/messages/conversations	Get list of recent conversations for the authenticated user. Includes last message preview, timestamp, unread count, and other participant details. Used for chat list display.	Patient/Doctor
GET	/api/messages/:userId	Get complete message history with specific user. Returns paginated messages in chronological order with read status, attachment information, and delivery timestamps.	Patient/Doctor
POST	/api/messages	Send new message. Accepts receiver_id, content, optional attachment. Creates message record in database, triggers real-time delivery via WebSocket to online recipients, and sends push notification to offline users.	Patient/Doctor
PUT	/api/messages/:id/read	Mark message as read. Updates is_read flag and timestamp, triggers read receipt via WebSocket to sender, and updates unread counts.	Patient/Doctor
DELETE	/api/messages/:id	Delete message (soft delete with audit trail). Only available within configurable time window (e.g., 1 hour) and requires reason. Message content is replaced with placeholder.	Patient/Doctor
GET	/api/messages/unread/count	Get count of unread messages across all conversations for badge notifications	Patient/Doctor

Table 3.19: Security Features Summary - Comprehensive overview of security controls implemented across all layers of the BondHealth platform. Each control is described with its implementation details and purpose.

Security Layer	**Implementation**	**Description**
Authentication	JWT with HTTP-only cookies	Tokens stored securely in HTTP-only cookies with Secure, HttpOnly, and SameSite flags preventing JavaScript access and CSRF attacks. 7-day expiration with refresh token rotation. Session invalidation on password change.
Password Security	Bcrypt with 10 salt rounds	Industry-standard password hashing with automatic salt generation. Minimum 8 characters with complexity requirements (uppercase, lowercase, number, special). Rate limiting on login attempts (5 attempts per 15 minutes) with account lockout.
Database Security	SSL connection to Neon PostgreSQL	All database connections require TLS 1.2+ encryption. Connection strings stored in environment variables, never in code. Database access restricted by IP whitelist. Row-level security for multi-tenant isolation.
Session Management	Server-side session tracking with Redis	Active sessions tracked in Redis with automatic expiration (30 minutes inactivity). Concurrent session limiting (max 5 per user). Force logout capability from any device. Session invalidation on password change or admin action.
Role-Based Access	Middleware route protection with RBAC	Hierarchical role system with permission inheritance. Route-level and data-level access controls. Hospital-scoped data isolation for multi-tenant security (doctors only see their patients).
Data Encryption	HTTPS/TLS for all communications	TLS 1.3 for all client-server communications. HSTS headers enforce HTTPS (max-age=31536000). Perfect forward secrecy with modern cipher suites. Car-

Table 3.20: Third-party Integrations - Comprehensive list of all external services integrated with the BondHealth platform, including purpose, implementation details, and compliance considerations. Each integration is chosen for reliability and healthcare compliance.

Integration	**Purpose**	**Implementation Details**
Stripe/Razorpay	Payment processing	RESTful API integration with webhooks for asynchronous notifications. PCI DSS Level 1 compliant. Supports multiple payment methods (cards, wallets, bank transfers, UPI). Handles subscriptions, one-time payments, and refunds. Webhook endpoints for payment success/failure, disputes, and refunds. Idempotency keys prevent duplicate charges.
Twilio/MessageBird	SMS notifications	API integration for sending transactional SMS. Templates for appointment reminders, lab report alerts, and critical notifications. Two-way SMS for patient responses (e.g., confirm appointment). Delivery status tracking with webhooks. Opt-out management (STOP keyword). Compliance with TCPA and local regulations.
SendGrid/NodeMailer	Email notifications	Email delivery with templates hosted on SendGrid (dynamic templates). Transactional emails (appointment confirmations, reports) and marketing emails (with consent). Open and click tracking for analytics. DKIM/SPF configuration for deliverability. Bounce handling and suppression lists. Webhooks for delivery events.
AWS S3/Azure Blob	File storage	Secure cloud storage for medical reports, images, and documents. Server-side encryption (AES-256). Lifecycle policies for archival (Glacier after 90 days) and deletion (after 7 years). Signed URLs for secure access (5-minute expiry). CORS configuration for direct browser uploads. Versioning enabled for critical documents.
Socket.io	Real-time chat	WebSocket library for bidirectional communication. Redis adapter for multi-server scalability (pub/sub). Authentication middleware with JWT. Room-based messaging for privacy. Fallback to long-polling for incompatible clients. Connection state recovery with acknowledgment.
Google Calendar API	Calendar sync	OAuth 2.0 integration for adding appointments to patient calendars. Create/update/delete events with reminders. Free/busy checking for avail-